Sicurezza dei sistemi informativi

Guida di studio avanzata, fondamenti teorici e risoluzione prove d'esame

Corso di laurea magistrale in Ingegneria informatica
Politecnico di Torino

Docente titolare: Prof. Cataldo Basile

Trattazione integrata con i testi di riferimento (Stallings, Schneier),
dati empirici ufficiali (Verizon DBIR, Cloudflare) e archivio storico delle prove d'esame.

Anno accademico 2026/2027

Sommario

Il presente volume costituisce la guida integrata e approfondita per il corso di **Sicurezza dei sistemi informativi** erogato presso il **Politecnico di Torino**. L'opera sviluppa in modo esaustivo e rigoroso tutti i pilastri della disciplina: le motivazioni socio-economiche del rischio cibernetico, l'evoluzione empirica delle minacce, i modelli formali della sicurezza e la gestione operativa dei sistemi complessi, integrando la letteratura scientifica fondamentale (*William Stallings*, *Bruce Schneier*) e la risoluzione analitica delle prove d'esame scritte e dei quiz Moodle degli ultimi quattordici anni accademici.

Indice

1 Introduzione alla sicurezza dei sistemi informativi **2**
1.1 La sicurezza informatica: motivazioni e dati . . . 2
1.2 Minacce e problemi di base . . . 10
1.3 Attacchi e tecniche . . . 12
1.4 Altri problemi e minacce . . . 19
1.5 Sicurezza: definizioni . . . 21
1.6 Principi di sicurezza . . . 24
1.7 I tre pilastri della sicurezza . . . 25

2 Gestione dei rischi informatici **26**
2.1 Fondamenti e terminologia del rischio . . . 26
2.2 Vulnerabilità e CVE – Common Vulnerabilities and Exposures . . . 28
2.3 CWE e window of exposure . . . 30
2.4 Window of exposure . . . 34
2.5 Risk Management Framework (RMF) . . . 36
2.6 Vulnerability assessment . . . 38
2.7 Valutazione del rischio . . . 42
2.8 Vulnerability management e patch management . . . 46

Capitolo 1

Introduzione alla sicurezza dei sistemi informativi

In termini generali, fare sicurezza significa portare i rischi a livelli accettabili, concetto la cui definizione richiede un'attenta contestualizzazione rispetto agli obiettivi organizzativi e alle risorse disponibili. Come formalizzato nella letteratura scientifica fondamentale della disciplina da William **Stallings** (*Computer Security: Principles and Practice*), dalle linee guida dello standard **NIST SP 800-33** e dall'impostazione metodologica del corso del Prof. Cataldo **Basile** presso il Politecnico di Torino, la sicurezza non può essere concepita come uno stato assoluto o binario, bensì come un equilibrio dinamico tra la minimizzazione delle vulnerabilità, la neutralizzazione di ogni potenziale **minaccia** e la sostenibilità operativa ed economica delle misure di protezione adottate.

1.1 La sicurezza informatica: motivazioni e dati

1.1.1 Alcune definizioni di sicurezza

È opportuno innanzitutto chiarire cosa si intenda per **sicurezza informatica**. Nel corso degli anni sono emerse diverse accezioni di questo concetto, ciascuna con specifiche sfumature di significato:

- Una prima definizione, di matrice aziendale, la identifica come:

  Definizione Formale: Sicurezza dei Sistemi Informatici — Prospettiva Aziendale

  L'insieme dei prodotti, dei servizi, delle regole organizzative e dei comportamenti individuali che proteggono i sistemi informatici di un'azienda.

  Questa prospettiva adotta un approccio pragmatico, sottolineando l'obiettivo di garantire il corretto funzionamento dei sistemi aziendali e la protezione degli **asset** anche in presenza di minacce provenienti da attori malevoli. Da questa formulazione emerge con evidenza come la sicurezza non sia un problema puramente tecnologico (risolvibile acquistando apparati o licenze software), bensì un sistema socio-tecnico integrato: la barriera tecnologica più avanzata viene vanificata se le regole organizzative non vengono applicate o se i singoli utenti mantengono comportamenti imprudenti (ad esempio aprendo allegati non verificati o scaricando software non autorizzato).
- Una seconda definizione, emersa successivamente, enfatizza invece:

Definizione Formale: Sicurezza delle Risorse e Proprietà Fondamentali

Il compito di proteggere le risorse da accessi indesiderati, garantire la riservatezza delle informazioni, assicurare il funzionamento e la disponibilità dei servizi a fronte di eventi imprevedibili.

In questo caso l'attenzione si concentra sulla prevenzione di accessi non autorizzati, sia da parte di attori criminali sia di soggetti concorrenti. Successivamente introduce quella che viene chiamata **Triade CIA** (*Confidentiality, Integrity, Availability*), tre concetti essenziali per poter costruire sistemi sicuri:

- **Riservatezza (Confidentiality):** riguarda la protezione della segretezza dei dati, impedendo che soggetti non autorizzati possano accedere a informazioni confidenziali.
- **Integrità (Integrity):** indica la necessità di preservare dati e sistemi da modifiche, cancellazioni o inserimenti non autorizzati, garantendo l'accuratezza e la completezza delle informazioni.
- **Disponibilità (Availability):** aspetto talvolta considerato al confine della sicurezza informatica in senso stretto, ma essenziale nella misura in cui mira a impedire che terzi possano compromettere l'erogazione tempestiva e affidabile dei servizi, causando gravissime perdite economiche e operative.

A queste proprietà canoniche, i modelli formali moderni (ISO/IEC 27000 e NIST) affiancano tre ulteriori proprietà cardine: l'**Autenticità** (certezza che l'identità dell'entità o l'origine del messaggio corrisponda a quella dichiarata), la **Tracciabilità** o *Accountability* (capacità di imputare inequivocabilmente ogni azione compiuta a un soggetto identificabile) e il **Non-Ripudio** (impossibilità per il mittente di negare la paternità di un messaggio o per il destinatario di negarne la ricezione, proprietà che richiede asimmetria probatoria opponibile a terzi e può essere garantita unicamente dalla firma digitale asimmetrica, non dalla crittografia simmetrica condivisa o da codici HMAC dove entrambe le parti possiedono la medesima chiave segreta e possono reciprocamente falsificare i messaggi).

- Una terza definizione riprende l'aspetto applicativo della prima e rappresenta la necessità di riportare il mondo informatico e virtuale all'esperienza fisica:

  > *"L'obiettivo è custodire le informazioni con la stessa professionalità ed attenzione con cui ci si prende cura di gioielli o certificati azionari depositati nel caveau. Il sistema informatico è la cassaforte delle nostre informazioni più preziose; la sicurezza informatica è l'equivalente delle serrature, combinazioni e chiavi che servono a proteggerla."*

  Questa prospettiva evidenzia la sicurezza informatica come trasposizione digitale dei meccanismi di protezione fisica tradizionalmente impiegati per la tutela di beni di valore. L'analogia chiarifica immediatamente la necessità di un approccio armonico:
  - Se la serratura a combinazione della cassaforte viene lasciata sulla sequenza di fabbrica predefinita (*default credential*), lo spessore dell'acciaio è del tutto ininfluente.
  - Se la chiave del caveau viene appesa a un gancio sulla parete adiacente (memorizzazione in chiaro di credenziali in script o database), chiunque può aprirla.
  - Se la guardia armata posta a presidio del caveau apre il portellone a un estraneo travestito da manutentore senza verificarne il tesserino (*ingegneria sociale*), l'intera infrastruttura crolla istantaneamente.

1.1.2 I motivi dell'importanza della sicurezza informatica

La sicurezza informatica è spesso percepita dai vertici aziendali come un investimento privo di ritorno immediato: l'implementazione di misure di protezione non genera profitto diretto e può,

al contrario, ridurre la produttività operativa. Tuttavia, un'analisi più approfondita evidenzia tre motivazioni fondamentali che ne giustificano l'essenzialità:

- **Ragioni economiche:** la progressiva digitalizzazione degli asset aziendali ha reso il patrimonio informativo un bene critico da proteggere. Gli istituti finanziari, ad esempio, operano quasi interamente su piattaforme digitali, rendendo evidente la necessità di tutelare tali risorse per prevenire danni economici. Per le organizzazioni, le conseguenze di una compromissione possono manifestarsi in molteplici forme: sottrazione di segreti industriali da parte di concorrenti, danno reputazionale derivante dalla violazione di dati sensibili dei clienti, interruzione prolungata dei servizi con conseguente perdita di ricavi e pagamento di penali per violazione dei *Service Level Agreement* (SLA).
- **Ragioni sociali ed etiche:** la sicurezza informatica riveste un ruolo essenziale nella protezione individuale e nella tutela della privacy. La correttezza nella gestione dei dati personali e la prevenzione dello sfruttamento illecito costituiscono diritti fondamentali che le organizzazioni sono tenute a garantire. Una compromissione può comportare gravi violazioni della riservatezza, esponendo informazioni sensibili degli utenti a utilizzi impropri, furti di identità o discriminazioni.
- **Ragioni di Stato:** la sicurezza informatica rappresenta oggi un elemento strategico per la difesa nazionale. Il contesto attuale è caratterizzato da una **guerra ibrida**, in cui gli Stati organizzano operazioni offensive e difensive attraverso il cyberspazio. A titolo esemplificativo, la Russia conduce campagne periodiche volte a destabilizzare l'Unione Europea, prassi storicamente adottata anche dagli Stati Uniti in contesti geopolitici differenti. Analogamente, la Cina ha istituito dipartimenti dedicati all'*offensive security* e alla penetrazione di reti estere, con l'obiettivo di acquisire proprietà intellettuale su scala globale, con particolare attenzione al contesto industriale e tecnologico occidentale.

Nel seguito del corso ci si concentrerà prevalentemente sulle **ragioni economiche**, in quanto più facilmente inquadrabili da una prospettiva ingegneristica.

In passato, le piccole e medie imprese ritenevano di non rappresentare obiettivi di interesse per gli attaccanti (*"perché mai qualcuno dovrebbe attaccare proprio noi?"*), limitando di conseguenza gli investimenti in sicurezza informatica. Tuttavia, è oggi evidente che la probabilità di subire un attacco è estremamente elevata per qualsiasi organizzazione, indipendentemente dalle dimensioni. Gli attori criminali adottano infatti strategie di tipo **pesca a strascico** (*mass automated attacks*): script e botnet scansionano ininterrottamente lo spazio globale degli indirizzi IP alla ricerca di qualsiasi porta aperta o servizio contenente una vulnerabilità nota. L'attaccante non mira a un marchio specifico, ma cerca un bersaglio facile con difese meno strutturate, massimizzando il proprio ritorno economico (*Return on Investment*, ROI) attraverso la numerosità statistica delle compromissioni. Questo è reso possibile da una grande abilità nell'automazione dello sfruttamento degli attacchi e dall'esistenza di una rete efficiente nel monetizzare gli effetti delle intrusioni (dati confidenziali, risorse computazionali, accessi non autorizzati).

Parallelamente, le grandi organizzazioni risultano vulnerabili ad attacchi più sofisticati mirati alla loro catena di fornitura: i **supply chain attacks**. Compromettendo fornitori, partner commerciali o componenti software di terze parti utilizzati dall'azienda target, gli attaccanti ottengono un accesso indiretto a sistemi altrimenti ben protetti. Queste tipologie di attacchi, particolarmente insidiosi, sfruttano le relazioni di fiducia tra organizzazioni e la complessità delle moderne catene di approvvigionamento digitali.

Nel complesso, possiamo dedurre che gli investimenti nella cybersecurity sono incrementati notevolmente nell'ultimo periodo perché, nella maggior parte dei casi, il danno economico conseguente a un attacco supera di gran lunga il costo degli investimenti preventivi in sicurezza. Le principali conseguenze economiche non si limitano ai **danni diretti** (ad esempio, trasferimenti fraudolenti di fondi), ma si articolano prevalentemente in **impatti indiretti**:

- **Deprezzamento del valore azionario** e perdita di capitalizzazione sul mercato;

- **Sanzioni amministrative**, quali quelle comminate dalle autorità garanti in caso di violazione del Regolamento Generale sulla Protezione dei Dati (**GDPR**, fino al 4% del fatturato globale annuo);
- **Costi di ripristino e bonifica**, comprendenti le spese per riportare i sistemi allo stato originale, ingaggiare team di risposta agli incidenti e implementare misure correttive;
- **Perdita di produzione**, con mancati guadagni derivanti da blocchi o rallentamenti operativi e penali contrattuali;
- **Perdita di clienti e commesse**, causata dal discredito e dall'erosione della fiducia conseguenti alla diffusione pubblica della notizia della violazione (*danno reputazionale*).

1.1.3 Insicurezza: le cause profonde

In seguito ai primi attacchi informatici di rilevanza pubblica negli Stati Uniti all'inizio degli anni 2000 (i clamorosi attacchi DDoS contro giganti del web quali Yahoo!, eBay, Amazon e CNN orchestrati dal malware *Mafiaboy*), l'amministrazione **Clinton** commissionò un documento analitico volto a identificare le cause profonde dell'insicurezza informatica. Le principali criticità strutturali individuate furono le seguenti:

1. **Evoluzione open-source e cooperativa delle tecnologie di attacco:** gli strumenti offensivi evolvono rapidamente e secondo un modello aperto, risultando ampiamente accessibili, modulari e facilmente adattabili da parte di chiunque.
2. **Approccio reattivo della difesa:** le metodologie difensive inseguono costantemente gli attaccanti. Una volta scoperta una vulnerabilità, il sistema bersaglio può essere protetto solo dopo lo sviluppo, il collaudo e l'applicazione delle patch di sicurezza, configurando un ritardo strutturale ineliminabile denominato **Window of Exposure** (*finestra di esposizione*).
3. **Proliferazione di sistemi insicuri connessi alla rete:** milioni di calcolatori legacy privi di adeguati controlli di sicurezza sono direttamente esposti a Internet; a distanza di vent'anni dalla relazione, a questi si sono aggiunti miliardi di dispositivi **IoT** (*Internet of Things*), spesso dotati di credenziali fisse e privi di meccanismi di aggiornamento.
4. **Carenza di competenze specialistiche:** la rapidissima espansione commerciale di Internet ha costretto le organizzazioni ad assumere personale sistemistico e operativo privo di formazione specialistica sulla sicurezza.
5. **Assenza di pratiche di programmazione sicura:** lo sviluppo del software è stato storicamente affidato a programmatori privi di nozioni di *secure coding*, orientati esclusivamente al rispetto delle scadenze di rilascio e all'aggiunta di funzionalità.
6. **Transnazionalità delle minacce:** gli attacchi oltrepassano istantaneamente i confini geografici e le sovranità nazionali, rendendo le indagini complesse ed inefficaci.
7. **Difficoltà dell'azione giudiziaria internazionale:** le discrepanze tra gli ordinamenti giuridici internazionali e la mancanza di cooperazione giudiziaria con taluni Stati rendono estremamente improbabile l'identificazione e il perseguimento effettivo dei responsabili.

Questa fragilità endemica dell'ecosistema di rete fu sintetizzata con straordinaria efficacia dall'esperto di sicurezza e giurista britannico **Nick Lockett** con una celebre massima:

> *"Internet is an inherently insecure network connecting inherently insecure computers."*
> (*"Internet è una rete intrinsecamente insicura che interconnette calcolatori intrinsecamente insicuri."*)

L'analisi formulata oltre due decenni fa mantiene piena attualità e, per certi aspetti, descrive una situazione nettamente peggiorata a causa dell'incremento esponenziale dei nodi interconnessi, della complessità dei servizi applicativi e della nascita di un'industria altamente organizzata del cybercrime.

1.1.4 Verizon Data Breach Investigation Report

Diverse organizzazioni e agenzie governative pubblicano periodicamente report di cybersecurity per scopi analitici e strategici. Tra questi, il punto di riferimento metodologico su scala globale è il celebre **Data Breach Investigations Report** (**DBIR**), redatto annualmente dalla divisione aziendale di **Verizon**. Il report aggrega ed esamina con rigore scientifico i dati empirici provenienti da decine di migliaia di incidenti di sicurezza confermati a livello mondiale, fornendo un quadro oggettivo ed epidemiologico dello stato reale della sicurezza informatica.

All'interno del framework DBIR si adotta una distinzione tassonomica essenziale:

- **Security Incident:** qualsiasi evento imprevisto o malevolo che compromette la riservatezza, l'integrità o la disponibilità di un sistema informativo o di un asset aziendale.
- **Data Breach:** un incidente confermato in cui dati sensibili, riservati o protetti vengono effettivamente esfiltrati, divulgati o sottratti a soggetti non autorizzati.

L'analisi integrata dei dati empirici collezionati nelle edizioni più recenti del report (dal DBIR 2021 al DBIR 2026) rivela parametri quantitativi e andamenti longitudinali cruciali per la gestione della sicurezza aziendale.

Costi Diretti e Costi Indiretti: L'impatto economico di una violazione non si esaurisce mai nella perdita monetaria immediata. Il DBIR classifica i costi generati da un incidente in due macro-categorie:

- **Costi Diretti:** conseguenze patrimoniali e finanziarie immediate scaturenti dall'attacco, quali bonifici fraudolenti disposti verso conti dell'attaccante, riscatti versati o danni materiali ai dispositivi.
- **Costi Indiretti:** oneri prolungati nel tempo che spesso superano di diversi ordini di grandezza il danno diretto, articolati in:
  1. *Spese tecnologiche aggiuntive di digital forensics:* costi per ingaggiare società terze specializzate nell'acquisizione delle prove informatiche, ricostruzione della *kill chain* e bonifica delle *backdoor* residue.
  2. *Spese legali e di compliance:* oneri per consulenze legali, contenziosi civili avviati da clienti o partner danneggiati, gestione delle notifiche obbligatorie alle autorità di protezione dei dati (ad esempio entro 72 ore ai sensi del GDPR) e sanzioni amministrative.
  3. *Perdita di valore azionario in borsa:* il monitoraggio empirico a lungo termine su società quotate (confrontate con l'andamento dell'indice NASDAQ a 6 mesi, $n = 39$) dimostra che la maggior parte delle aziende violate subisce un calo azionario mediano di circa il **-5% già a una settimana** dall'annuncio dell'incidente; tale trend negativo non si riassorbe nel breve termine, ma **persiste per almeno due anni**, registrando flessioni che toccano il -31% o il -50% nei casi più gravi.

Dall'analisi delle distribuzioni empiriche delle perdite monetarie (n incidenti analizzati) emerge un divario strutturale tra la **perdita mediana** e la **perdita massima**, causato dalla presenza di una coda lunga ad altissimo impatto economico:

Tipologia di Evento	Campione	Senza Perdita	Mediana	75° Percentile	Perdita Massima / Note
Business Email Compromise (BEC)	$n = 19.296$	42%	\$30.000	\$305.000	Picchi fino a \$984.855
Computer Data Breach (CDB)	$n = 2.781$	76%	\$29.774	\$438.499	Massimo storico di \$1.594.648
Ransomware (costo diretto)	$n = 2.475$	90%	\$11.150	\$296.500	Oltre \$1.155.775 (esclusi costi indiretti)
Analisi Forense (Forensics)	$n = 50$	50%	\$18.124	\$136.120	Raggiunge \$336.499
Spese Legali (Legal)	$n = 50$	36%	\$4.027	\$22.423	Raggiunge \$53.691

Tabella 1.1: Distribuzione statistica dei costi diretti e indiretti per categoria di incidente (Dati DBIR).

Principali Attori della Minaccia (Threat Actors): L'indagine empirica evidenzia l'origine e la natura degli agenti malevoli coinvolti nelle violazioni confermate (DBIR 2025 e DBIR 2026, $n = 22.345$):

- **Attori Esterni (88%):** costituiscono la stragrande maggioranza delle intrusioni. All'interno di questo gruppo, il **Crimine Organizzato (Organized Crime)** detiene la prevalenza assoluta (oltre il 65–70% delle violazioni totali); si tratta di una vera e propria industria strutturata il cui giro d'affari globale stimato ha superato i **1.000 miliardi di dollari (1 Trillion $)** già nel biennio 2019/2020.
- **Attori Interni (12%):** la componente interna (*Insider Threat*) rappresenta una quota non trascurabile. Dimostra inconfutabilmente che un'organizzazione non può riporre una fiducia incondizionata nel personale o negli amministratori di sistema: accessi privilegiati abusati, dipendenti infedeli o collaboratori distratti possono vanificare le difese perimetrali.
- **Attori Statali (State-Sponsored / Nation-State, 5–10%):** agenzie di intelligence governative e gruppi APT ($n = 1.892$). Per questi attori, la motivazione primaria è lo **Spionaggio industriale e geopolitico (74%)**, seguito da interessi finanziari (28%) e sabotaggio secondario (26%).
- **Coinvolgimento dell'Elemento Umano (Human Element, 62%):** il DBIR 2026 certifica che nel **62% dei breach** complessivi è presente un errore o un'azione umana determinante (caduta in trappole di phishing, uso improprio di credenziali o configurazioni errate).

Motivazione degli Attaccanti Esterni: Se a livello aggregato globale il guadagno economico costituisce la molla prevalente (89% nel DBIR 2025 e 96% nel DBIR 2022), un'analisi stratificata in base alla dimensione dell'organizzazione rivela una profonda discrepanza:

- **Tutte le Organizzazioni (campione dominato da PMI):** il movente è quasi esclusivamente finanziario (**96%**); le azioni dettate da disaccordo/protesta (3%), divertimento o curiosità (2%) e rancore personale (1%) risultano residuali. Le PMI sono considerate bancomat digitali da colpire con scansioni e attacchi automatizzati a basso costo.
- **Grandi Organizzazioni e Multinazionali (Larger Orgs):** la componente finanziaria scende al **71%**, lasciando spazio a motivazioni ideologiche e personali: il disaccordo e la protesta sociale salgono al **25%**, mentre il divertimento, la curiosità e la ricerca di prestigio tecnico (*"fun, curiosity, pride"*) raggiungono il **23%**. I grandi marchi attirano hacktivisti e attaccanti alla ricerca di visibilità globale.

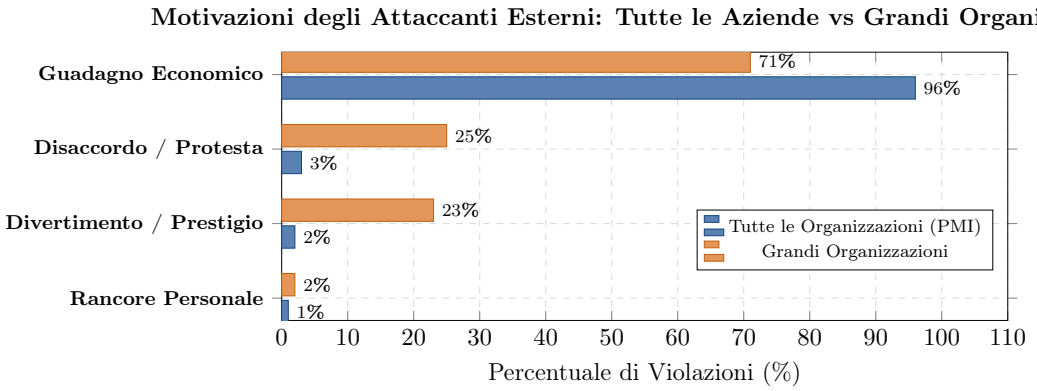


Figura 1.1: Confronto delle motivazioni degli attaccanti esterni tra la media globale e le grandi organizzazioni (Dati Verizon DBIR).

Access Vector (Punto di Partenza) e Trend Recenti: L'access vector identifica la vulnerabilità iniziale o la debolezza sfruttata per violare il perimetro aziendale. Formalmente:

Definizione Formale: Vulnerabilità

Una vulnerabilità è una debolezza intrinseca di progettazione, implementazione, configurazione o gestione che può essere sfruttata da una minaccia per compromettere un sistema o un asset.

L'analisi longitudinale documenta un'evoluzione storica impressionante:

- **Sorpasso dello Sfruttamento di Vulnerabilità (Exploitation of Vulnerabilities):** balzato dal **14% nel 2024**, al **20% nel 2025**, fino a toccare il **31% nel 2026**. È divenuto il **primo vettore d'ingresso assoluto** nelle violazioni non accidentali, trainato dall'adozione massiccia di dispositivi di bordo (*edge appliances*), VPN e software esposti su Internet affetti da vulnerabilità note non corrette (*unpatched*).
- **Flessione dell'Abuso di Credenziali Rubate (Credential Abuse):** storicamente dominante (38–40% nel 2022–2023), è sceso al 22% nel 2025 e si attesta al **15–16% nel 2026**. Tale contrazione testimonia l'efficacia dell'autenticazione a più fattori (MFA) e delle chiavi FIDO2/Passkey.
- **Phishing e Pretexting:** il phishing mantiene un'incidenza stabile tra il **14% e il 17%**, affiancato dal pretexting (ingegneria sociale mirata) al **5–6%**.

I trend di sintesi evidenziati dal DBIR 2026 comprendono inoltre:

- **48% degli attacchi coinvolge ransomware:** la quota rimane elevatissima (dopo il picco aggregato con l'estorsione al 62% nel 2024 e al 44% nel 2025).
- **48% coinvolge terze parti (Supply Chain):** il coinvolgimento di fornitori, librerie open-source ed ecosistemi partner è più che triplicato (era il 15% nel 2024 e il 30% nel 2025), consolidando gli attacchi a monte quale vettore preferenziale.
- **69% delle vittime di ransomware rifiuta di pagare:** la stragrande maggioranza delle organizzazioni decide di non pagare il riscatto, confidando in procedure di ripristino da backup offline e nel timore di sanzioni per finanziamento al terrorismo.
- **Impiego di Malware Potenziato da AI Generativa (GenAI-Augmented):** comparsa di malware polimorfico e campagne di phishing iper-personalizzate generate algoritmicamente.

Principali Asset Bersagliati e Varietà di Dati: Formalmente, un **asset** è qualsiasi risorsa materiale o immateriale dotata di valore per l'organizzazione che necessita di adeguata protezione. I dati empirici identificano la concentrazione degli attacchi sui seguenti nodi:

- **Server (95% delle violazioni totali):** rimangono il bersaglio principale in assoluto. Nel dettaglio delle varietà di server colpite:
  - *Web Application Server (54%):* costituiscono la superficie pubblica esposta e il punto di transito di dati transazionali.
  - *Mail Server (30%):* snodo fondamentale per comunicazioni interne, reset di credenziali e veicolazione di allegati infetti.
  - *Server di gestione e accesso remoto (10%):* gateway VPN e terminal server.
- **Persone (24% nel 2025, 13% dipendenti/end-user nel 2026):** dipendenti ingannati o indotti a compiere azioni nocive.
- **Dispositivi Utente (User Devices, 7%):** workstation desktop, personal computer portatili e smartphone aziendali.
- **Supporti Fisici di Memorizzazione (Media, 2.4%):** dischi rigidi, memorie flash o apparati dismessi senza preventiva cifratura o degaussing.

In merito alle **varietà di dati compromessi** (*Top Data Varieties*, $n = 12.063$), la distribuzione quantitativa vede in testa i dati interni aziendali (**Internal, 50%**), seguiti da dati personali comuni (**Personal PII, 32%**), credenziali di accesso (**Credentials, 19%**), file e registri di sistema (**System, 12%**), segreti crittografici, certificati e chiavi API (**Secrets, 12%**), cartelle

cliniche e dati sanitari (**Medical, 9%**), dettagli di conti bancari (**Bank, 6%**), dati personali altamente sensibili (**Sensitive Personal, 4%**), chiavi di sessione (**Session Key, 3%**) e dati relativi a carte di pagamento (**Payment, 1.2%**).

Tipologie di Attacco e Debolezze Matrici: Un **attacco** è formalmente definito come un'azione deliberata che tenta di compromettere la confidenzialità, l'integrità o la disponibilità di un asset. I report strutturano le cause scatenanti su quattro debolezze cardine:

1. *Debolezze tecnologiche intrinseche:* protocolli di rete storicamente progettati privi di cifratura o autenticazione; la sicurezza incrementa la complessità del sistema, favorendo nuove falle.
2. *Debolezze degli utenti:* mancata consapevolezza degli effetti delle proprie azioni, unite a stati psicologici di stanchezza, fretta, risentimento o curiosità.
3. *Debolezze organizzative:* investimenti insufficienti in sicurezza, carenza di personale tecnico qualificato e mancata applicazione di policy rigorose di backup e segmentazione.
4. *Debolezze dei produttori di software:* rilascio continuo sul mercato di codice applicativo difettoso e non revisionato, pieno di bug di corruzione della memoria o logica applicativa.

Le azioni prevalenti documentate nelle violazioni ($n = 10.747$) comprendono l'impiego di Ransomware (44%), l'uso di credenziali rubate (32%), l'exploit di vulnerabilità (18%), il phishing (14%), l'installazione di backdoor e canali C2 (14%), l'evasione dei sistemi di difesa (13%), la scansione di rete (10%), lo sfruttamento di errate configurazioni (10%), l'esfiltrazione dati (9%) e la disattivazione forzata dei controlli di sicurezza (9%).

Tempo per Rendersi Conto (Time-to-Detection / Dwell Time): Uno dei parametri più allarmanti emersi dall'indagine empirica riguarda la permanenza silente dell'attaccante all'interno della rete vittima prima di essere scoperto (**dwell time**). Escludendo le violazioni comunicate dall'attaccante stesso (come avviene nel ransomware con la visualizzazione della schermata di riscatto), la distribuzione del dwell time evidenzia:

- Nel 2022, il tempo mediano di permanenza silente prima della rilevazione era di **30 giorni**.
- Nel 2024, la mediana è scesa a **24 giorni**.
- Tuttavia, la distribuzione presenta una lunghissima coda destra: moltissime intrusioni superano i **100 giorni** e non mancano casi che si protraggono per oltre **1.000 giorni** (quasi tre anni di spionaggio inosservato all'interno dei sistemi aziendali).

I canali attraverso cui avviene la scoperta dell'intrusione (*Discovery Methods*, $n = 204$) si distribuiscono in modo eterogeneo:

- **Monitoraggio continuo dell'infrastruttura (18%):** sistemi SIEM, SOC, sensori EDR e IDS.
- **Segnalazione interna dei dipendenti (14%):** anomalie riscontrate dal personale d'ufficio.
- **Segnalazione da parte dei clienti (10%):** clienti che informano l'azienda di aver ricevuto comunicazioni fraudolente o trovato i propri dati sul dark web.
- **Software Antivirus (9%):** rilevazione automatica di firme o euristiche su endpoint.
- **Revisione periodica dei log di audit (8%):** analisi retrospettiva dei file di registro.
- **Notifica da parte delle Forze dell'Ordine (7%):** agenzie investigative che rinvengono i dati aziendali sequestrando server criminali.
- **Segnalazione da Ricercatori di Sicurezza / Ethical Hacker (7%):** comunicazioni di vulnerabilità o leak.
- **Altri canali non strutturati (28%):** scoperte fortuite o casuali durante manutenzioni ordinarie.

Tempo di Recupero e Bonifica (Time-to-Resume / Remediate): Risolvere le vulnerabilità e bonificare l'infrastruttura dopo un incidente richiede tempi considerevolmente lunghi, come dimostrano le statistiche longitudinali:

- **Bonifica di vulnerabilità su apparati di bordo (Edge Devices, $n = 431$):** mentre i primi interventi avvengono entro 1–6 giorni, la **mediana di bonifica completa si attesta a 32 giorni**, il 75° percentile sale a **155 giorni** e i casi complessi richiedono fino a **222 giorni**.
- **Bonifica di segreti e chiavi API trapelate su repository Git ($n = 141$):** la revoca e rotazione delle credenziali esposte registra un tempo del 25° percentile di 32 giorni, una **mediana di 94 giorni** e un 75° percentile di **162 giorni**.
- **Bonifica di vulnerabilità note sfruttate attivamente (CISA KEV, $n = 10.597$):** anche per falle critiche catalogate con exploit pubblico in circolazione, il tempo mediano di patching è di **43 giorni**, con il 75° percentile a **107 giorni** e tempi massimi che oltrepassano i **169 giorni**.

—

1.2 Minacce e problemi di base

L'analisi che segue si propone di illustrare i fattori storici, architetturali e metodologici che hanno condotto all'attuale scenario di vulnerabilità sistemica.

1.2.1 Problemi tecnologici di base

La sicurezza informatica è una problematica relativamente recente. Durante la progettazione delle prime reti di calcolatori (ARPANET negli anni Settanta), l'obiettivo primario era garantirne il funzionamento operativo, la robustezza delle comunicazioni in caso di guasti distribuiti e l'interoperabilità tra centri di ricerca universitari e strutture militari. La sicurezza non era considerata una priorità progettuale, poiché la rete costituiva un ambiente chiuso, composto da un numero limitato di nodi noti e gestiti da operatori reciprocamente fidati; l'infrastruttura non era minimamente accessibile al pubblico. Inoltre, l'impiego massivo di meccanismi crittografici comportava un costo computazionale proibitivo, insostenibile per i microprocessori dell'epoca.

Per accedere a Internet, utenti privati e organizzazioni stipulano contratti con gli **Internet Service Provider (ISP)**, i quali forniscono la connettività transitando i pacchetti sui propri router e dorsali. In passato si sono verificati casi concreti in cui dipendenti o tecnici di ISP hanno intercettato, sottratto o rivenduto informazioni riservate transitate sulle proprie infrastrutture, oppure hanno applicato politiche di instradamento anomale (ad esempio alterazioni BGP) per dirottare o frodare il traffico di determinati utenti. In generale, dalla prospettiva di un'azienda, **un ISP non è un ente intrinsecamente fidato**: può essere soggetto a intercettazioni governative, violazioni interne o rivelarsi persino un competitor commerciale. Poiché tutto il traffico non cifrato che attraversa i nodi dell'operatore è tecnicamente accessibile, si rende indispensabile l'uso sistematico della crittografia end-to-end.

Un ulteriore problema strutturale riguarda l'autenticazione degli utenti, storicamente demandata a password statiche che risultano del tutto inadeguate a causa dell'uso di combinazioni banali, del loro riutilizzo su molteplici servizi e della suscettibilità agli attacchi di intercettazione. Infine, la programmazione software continua ad essere affetta da gravi carenze qualitative, rilasciando codice privo di validazione sui confini di memoria e sui parametri di input.

1.2.2 Complessità

Storicamente, la sicurezza informatica era circoscritta alla protezione del sistema operativo dell'elaboratore centrale. L'architettura tradizionale delle origini prevedeva un grande *mainframe* e N postazioni terminali prive di capacità computazionale autonoma (costituite esclusivamente da monitor e tastiera per l'immissione di comandi). In un simile contesto centralizzato, proteggere il sistema operativo e l'accesso fisico alla sala macchine equivaleva a proteggere l'intera infrastruttura aziendale.

Con l'evoluzione tecnologica, il panorama è mutato radicalmente: si è assistito alla proliferazione incontrollata di calcolatori distribuiti, stazioni di lavoro personali, computer portatili, fino all'avvento ubiquo degli smartphone e dei sensori intelligenti. Parallelamente, le architetture di rete hanno subito una metamorfosi profonda con la transizione verso data center distribuiti, piattaforme cloud (*IaaS, PaaS, SaaS*), paradigmi di *edge computing*, *fog computing* e *liquid computing*. In questo scenario altamente distribuito e virtualizzato, diventa spesso impossibile determinare a priori il luogo fisico e logico di esecuzione delle applicazioni o di memorizzazione dei dati, rendendo oltremodo complessa l'identificazione del **perimetro di sicurezza** da presidiare.

Nel contesto odierno, ogni tentativo di implementare efficaci misure di sicurezza si scontra con una legge fondamentale dell'informatica:

Definizione Formale: Primo Assioma dell'Ingegneria della Sicurezza

Più un sistema è complesso, più è difficile verificarne la correttezza (progettazione, implementazione, gestione, funzionamento).

Un sistema operativo moderno o una piattaforma di virtualizzazione è costituita da decine di milioni di linee di codice sorgente; è matematicamente e praticamente impossibile garantire l'assenza totale di difetti. La superficie d'attacco cresce esponenzialmente con la complessità del sistema.

Il paradigma progettuale cardine da adottare per contrastare questa fragilità è il celebre principio **KISS** (*Keep It Simple, Stupid*): mantenere il sistema il più semplice e lineare possibile. Maggiore è la complessità architetturale e il numero di componenti interconnessi, maggiore è la probabilità statistica che un attaccante individui una falla sfruttabile per penetrare nell'infrastruttura.

1.2.3 Altri problemi tecnologici

Ulteriori criticità di natura tecnologica che affliggono i moderni sistemi informativi possono essere ricondotte a quattro classi principali:

- **Problemi di programmazione (Implementation Flaws):** il software contiene bug implementativi derivanti dalla mancata applicazione dei principi di *secure coding*. Rientrano in questa classe le vulnerabilità di gestione della memoria nei linguaggi non *memory-safe* come C/C++ (*buffer overflow, heap corruption, use-after-free*), la mancata sanificazione dei parametri di input (suscettibile a iniezioni SQL, neutralizzabili strutturalmente solo mediante l'adozione di **Prepared Statements**, ovvero query parametrizzate precompilate dal database engine, comandi shell o cross-site scripting) e la gestione non corretta delle eccezioni e dei puntatori nulli.
- **Problemi di progettazione (Design Flaws):** la sicurezza viene ignorata nelle fasi concettuali e architetturali preliminari, per essere aggiunta unicamente come modulo integrativo a posteriori (*patching reattivo*). L'esperienza empirica dell'ingegneria del software dimostra che i difetti architetturali non possono essere corretti mediante semplici patch, ma richiedono la riscrittura e la riprogettazione integrale del sistema.
- **Configurazione di dispositivi e servizi (Hardening):** una configurazione inadeguata o approssimativa di sistemi operativi, server web e database espone interfacce amministrative e servizi superflui direttamente verso Internet. Il processo di **hardening** (*irrobustimento*) consiste nella sistematica riduzione della superficie d'attacco attraverso la disabilitazione delle porte non utilizzate, la rimozione degli account di prova, l'attivazione di privilegi minimi e l'applicazione tempestiva delle correzioni di sicurezza.

- **Complessità gestionale dei controlli di sicurezza:** gli stessi apparati deputati alla protezione dei sistemi informativi (firewall perimetrali, router filtranti, piattaforme IDPS) presentano una complessità di configurazione tale da indurre frequentemente in errore gli operatori. In contesti aziendali eterogenei, la gestione delle regole perimetrali richiede la definizione di insiemi di criteri vastissimi. Studi scientifici sul tema (quali l'indagine condotta da Avishai **Wool** nel 2010 sull'analisi empirica delle policy di filtraggio aziendali) hanno rivelato la presenza di **decine di migliaia di regole attive** all'interno dei singoli firewall aziendali. La gestione di tale mole di istruzioni eccede ampiamente le capacità cognitive umane: conflitti tra regole, ridondanze, shadowed rules e aperture indiscriminate finiscono per vanificare completamente la protezione perimetrale, consentendo l'infiltrazione silenziosa del traffico malevolo. Inoltre, per proteggere i sistemi nell'intervallo temporale che precede lo sviluppo e il rilascio delle correzioni software da parte dei vendor, le organizzazioni ricorrono al **Virtual Patching**: l'attivazione tempestiva di regole di filtraggio perimetrali (a livello di WAF o IPS) capaci di intercettare e scartare i vettori di exploit noti.

—

1.3 Attacchi e tecniche

L'analisi che segue esamina ad alto livello una serie di attacchi fondamentali, comunemente diffusi nell'ambiente di rete, presentando per ciascuno la dinamica operativa, gli scenari visuali e le contromisure note ed efficaci.

1.3.1 Packet sniffing

Il **packet sniffing** è una tecnica di attacco che consiste nell'intercettazione e lettura passiva di pacchetti di dati in transito su un canale di rete, non destinati all'elaboratore dell'attaccante. In assenza di protocolli crittografici, il payload dei pacchetti risulta interamente in chiaro, consentendo all'intruso di estrarre credenziali di autenticazione, session cookie, testi di email o documenti riservati. Tali informazioni possono essere impiegate in modo diretto per accedere ad account protetti, oppure in modo indiretto per mappare la topologia interna dell'organizzazione ed evidenziare bersagli vulnerabili.

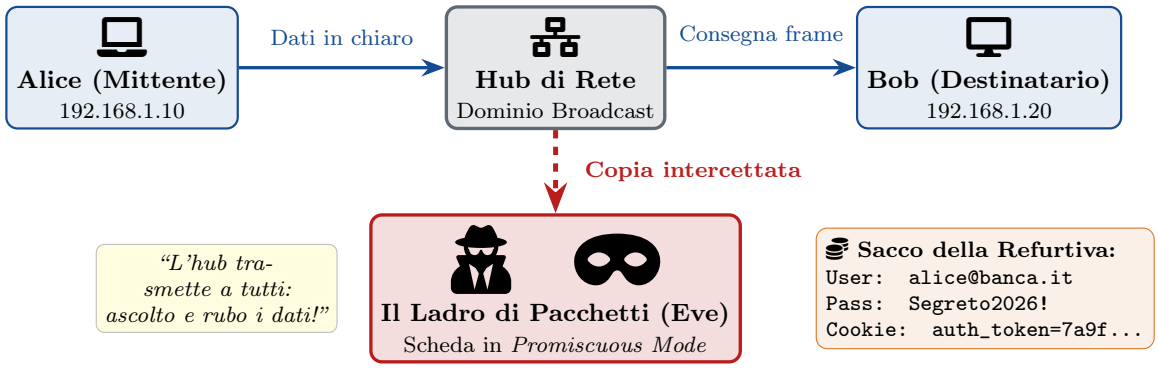


Figura 1.2: Scenario operativo del Packet Sniffing: il ladro (Eve) sfrutta la natura broadcast dell'hub e la scheda in modalità promiscua per catturare le credenziali in chiaro.

Le reti locali sono state storicamente progettate per essere **broadcast** (impiegando ripetitori multiporta denominati *hub*) per minimizzare i costi di cablaggio e semplificare l'instradamento: ogni frame trasmesso da un host viene replicato fisicamente su tutte le porte. Per condurre l'attacco, l'intruso deve semplicemente impostare la propria scheda di interfaccia di rete (NIC) in **modalità promiscua** (*promiscuous mode*), disabilitando il filtro hardware che scarta i frame

recanti indirizzi MAC diversi dal proprio. Nelle reti moderne l'impiego di **switch** al posto degli hub riduce parzialmente l'impatto di questo problema, inoltrando i pacchetti solo verso la specifica porta fisica del destinatario; tuttavia, l'attaccante può forzare lo switch ad operare come un hub mediante tecniche di *ARP Poisoning / ARP Spoofing* o saturando la memoria della tabella dei MAC (*MAC Flooding*).

Contromisure Efficaci: La difesa strutturale definitiva risiede nella **cifratura robusta end-to-end del payload** a livello applicativo o di trasporto (mediante protocolli sicuri quali TLS, SSH o tunnel IPsec): se i pacchetti intercettati contengono esclusivamente sequenze pseudocasuali inintelligibili, lo sniffing risulta completamente sterile.

1.3.2 IP spoofing

Per **IP spoofing** si intende la deliberata falsificazione dell'indirizzo IP del mittente inserito nell'intestazione del pacchetto di livello 3 dello stack OSI. La manipolazione dell'indirizzo IP sorgente è un'operazione tecnicamente agevole per chiunque disponga di privilegi amministrativi (*root* o amministratore) sul proprio dispositivo, sfruttando le interfacce per la creazione di *raw socket* o specifici tool da riga di comando. Per questa ragione, nelle reti aziendali i privilegi di amministratore non vengono mai concessi indiscriminatamente alle postazioni di lavoro.

Questa tecnica consente a un malintenzionato di bypassare meccanismi di controllo dell'accesso basati sull'indirizzo IP, oppure di deviare risposte malevole verso una vittima designata. Poiché anche la falsificazione dell'indirizzo di livello 2 (MAC) è banale modificando le impostazioni dei driver o configurando le interfacce delle macchine virtuali, è più corretto parlare in senso generale di **source address spoofing**. Ne consegue un principio cardine della sicurezza: **non è assolutamente possibile fare affidamento sugli indirizzi di livello 3 o di livello 2 per garantire l'autenticità di una comunicazione**.

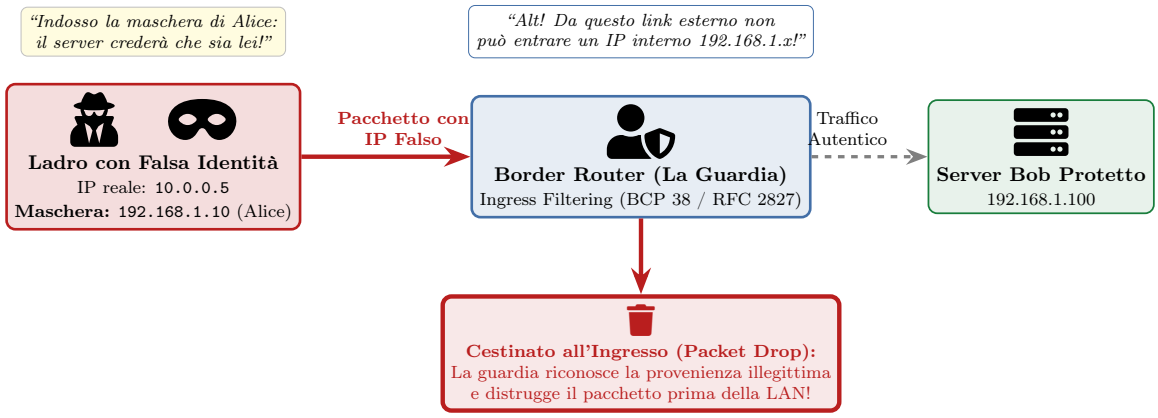


Figura 1.3: Scenario operativo di IP Spoofing: il ladro tenta di penetrare spacciandosi per Alice, ma viene intercettato e cestinato dal Border Router mediante Ingress Filtering (BCP 38).

Contromisure Strutturali: A livello di rete perimetrale, la misura standard di contenimento è l'**Ingress Filtering** formalizzato nello standard BCP 38 (**RFC 2827**): i router di confine verificano che i pacchetti in ingresso provengano da una subnet coerente con l'interfaccia fisica di ricezione, distruggendo istantaneamente pacchetti recanti indirizzi interni forgiati provenienti da collegamenti esterni. A livello sistemico, la mitigazione definitiva richiede protocolli di autenticazione crittografica cruda (firme digitali, HMAC, handshake mutuali).

1.3.3 Shadow (or fake) server

Nell'attacco di tipo **shadow server** (o server ombra/falso), un elaboratore non autorizzato controllato dall'attaccante si spaccia per un server di rete legittimo, inducendo i client a connettersi ad esso. L'inganno può essere condotto tramite packet sniffing per intercettare la richiesta originaria seguito da IP spoofing per simulare la provenienza autentica, oppure mediante avvelenamento delle risposte di risoluzione dei nomi (**DNS Cache Poisoning**). In altri casi, la tecnica sfrutta l'assenza intrinseca di autenticazione in protocolli di autoconfigurazione locale di rete, quale il protocollo **DHCP**: un server DHCP malevolo (*Rogue DHCP Server*) risponde alle richieste `DHCPDISCOVER` dei client assegnando loro parametri di rete arbitrari (proprio IP come default gateway o come resolver DNS).

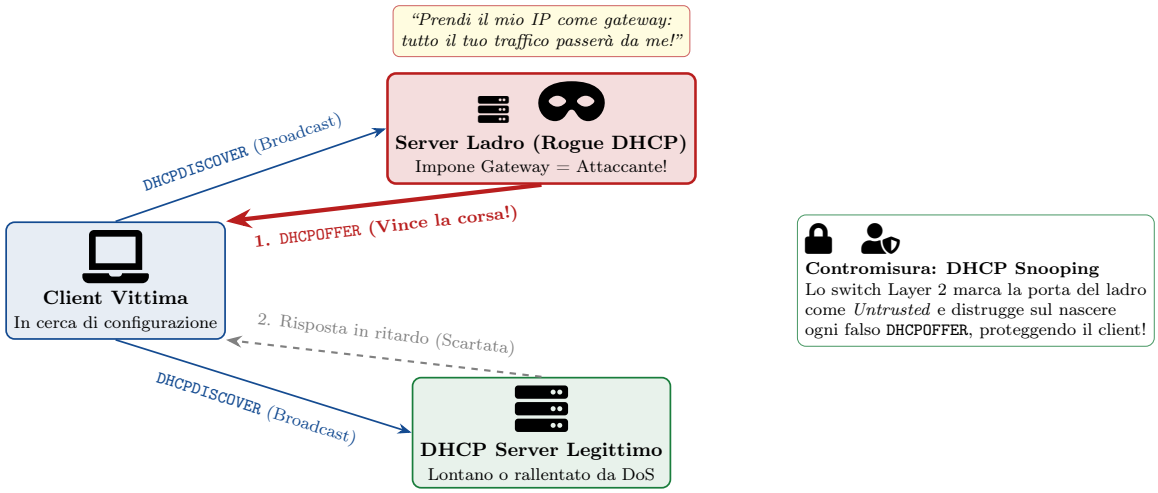


Figura 1.4: Dinamica di race condition nello Shadow DHCP Server: il server ladro tenta di ingannare il client offrendo parametri malevoli, contrastato dal DHCP Snooping su switch.

Affinché l'attacco abbia successo, il server falso deve vincere una condizione di concorrenza (*race condition*), rispondendo al client più celermente rispetto al server legittimo; per questa ragione, spesso l'attaccante combina l'attacco saturando preliminarmente il server autentico mediante un attacco DoS. L'obiettivo primario risiede nel fornire servizi contraffatti per carpire credenziali o porsi come intermediario (*Man-in-the-Middle*).

Contromisure: Negli apparati di commutazione locali, la difesa hardware standard è il **DHCP Snooping**, che classifica le porte fisiche in *Trusted* (autorizzate a propagare messaggi DHCP server) e *Untrusted* (dove i pacchetti `DHCPOFFER` vengono immediatamente bloccati e distrutti). A livello applicativo, la contromisura universale è il protocollo **TLS**, che impone l'autenticazione unilaterale del server mediante certificati digitali X.509 emessi da Certification Authority riconosciute, preservando l'anonimato del client.

1.3.4 Denial of Service (DoS)

Con il termine **Denial of Service (DoS)** si identificano tutte le tipologie di attacco mirate a saturare deliberatamente le risorse fisiche o computazionali di un host, server o apparato di rete (capacità di banda, cicli CPU, memoria RAM, descrittori di socket o connessioni attive), impedendogli di rispondere alle richieste legittime e compromettendone la disponibilità per un periodo di tempo più o meno prolungato.

Un esempio canonico è il **TCP SYN Flood**: l'attaccante emette un flusso ininterrotto di pacchetti recanti il flag TCP SYN verso una determinata porta aperta del server, forgiando

indirizzi IP sorgente casuali o inesistenti. Il server alloca una struttura di memoria (*Transmission Control Block*, TCB) all'interno della coda delle connessioni semi-aperte (*backlog queue*) e risponde con un pacchetto SYN-ACK. Non ricevendo alcun ACK conclusivo (poiché gli IP sono inesistenti), le risorse della tabella rimangono occupate fino allo scadere del timeout, saturando la coda e provocando il blocco totale di qualsiasi nuova richiesta proveniente da utenti legittimi. La contromisura tecnica universalmente adottata a livello di sistema operativo risiede nel meccanismo del **SYN Cookie** (*SYN Cookies*): il server non memorizza alcun descrittore di connessione al ricevimento del SYN, ma codifica lo stato della sessione all'interno del numero di sequenza iniziale (*Initial Sequence Number*, ISN) del pacchetto SYN-ACK; se il client risponde con un ACK valido, il server ricostruisce crittograficamente la sessione solo in quel momento.

Non esiste tuttavia una soluzione magica o definitiva contro gli attacchi DoS volumetrici: il sovradimensionamento dell'infrastruttura costituisce un rimedio parziale, poiché il volume dell'attacco può sempre eccedere la larghezza di banda contrattualizzata. Lo strumento più efficace di contenimento rimane la collaborazione attiva e tempestiva con i propri fornitori di connettività (ISP), i quali possono applicare regole di instradamento verso buchi neri (*BGP Blackhole Routing*) per deviare il flusso malevolo a monte.

1.3.5 Distributed Denial of Service (DDoS)

Con l'aumento esponenziale della capacità trasmissiva dei data center e delle corporation, gli attacchi DoS tradizionali generati da un singolo host sono divenuti pressoché inefficaci contro bersagli strutturati. Per superare questa limitazione si è evoluta la variante distribuita: il **DDoS** (*Distributed Denial of Service*).

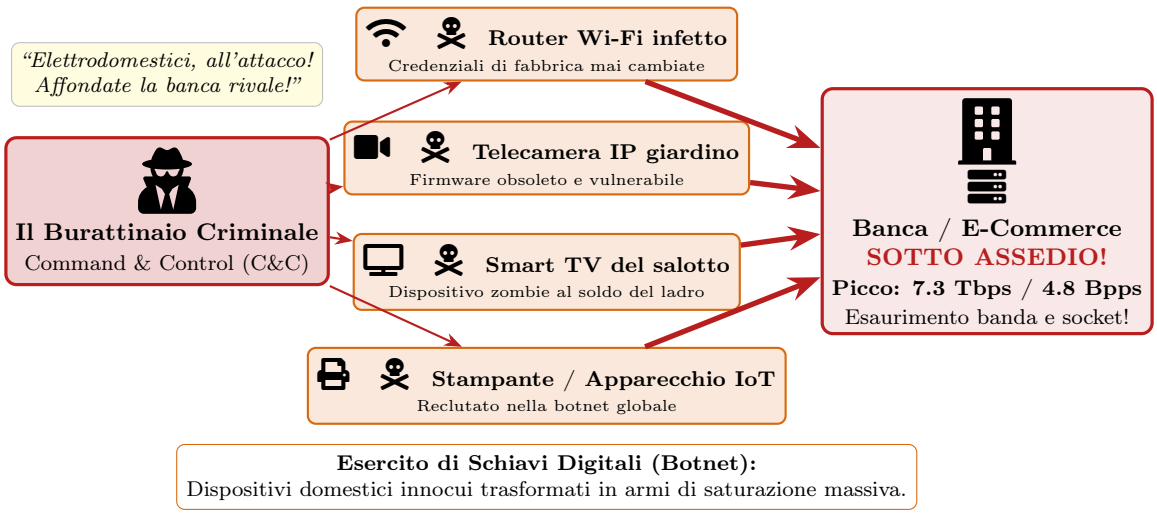


Figura 1.5: Architettura di un attacco DDoS orchestrato da un burattinaio criminale tramite botnet di elettrodomestici e apparati IoT compromessi.

In questo scenario vengono coinvolti centinaia di migliaia o milioni di dispositivi compromessi denominati **daemon** o **malbot**, che insieme costituiscono una **botnet**. Questi nodi, spesso elettrodomestici connessi o router domestici infettati all'insaputa dei legittimi proprietari mediante il download di file infetti o lo sfruttamento di credenziali predefinite, vengono coordinati tramite server centralizzati di *Command & Control* (C&C) per proiettare simultaneamente volumi massivi di pacchetti verso il target designato.

Il fenomeno ha assunto dimensioni spaventose: secondo i report tecnici pubblicati da **Cloudflare**, primaria rete CDN globale, la potenza degli attacchi DDoS registra record continui:

Nel 2025 sono stati documentati attacchi volumetrici che hanno raggiunto picchi inauditi di **7.3 Terabit al secondo (Tbps)** e flussi di oltre **4.8 miliardi di pacchetti per secondo (Bpps)**, eclissando i record di 3.5 Tbps registrati nel 2024.

Tra i mandanti più attivi emergono spesso i **competitor commerciali diretti**: in settori a redditività immediata (quali e-commerce, piattaforme di gaming o scommesse online), condurre un attacco DDoS durante giornate critiche (il Black Friday o lanci di prodotto) comporta l'immediata fuga dei clienti verso piattaforme rivali percepite come più affidabili. La commercializzazione di servizi **DDoS-as-a-Service** su portali del dark web consente a chiunque, a fronte di poche decine di dollari, di noleggiare campagne di sabotaggio su vasta scala.

1.3.6 Man In The Middle (o connection hijacking)

Negli attacchi di tipo **Man-in-the-Middle (MITM)**, l'attaccante si interpone fisicamente o logicamente nel canale di comunicazione tra due host (Alice e Bob), acquisendo la capacità di intercettare, manipolare, eliminare o iniettare pacchetti in tempo reale. Quando l'intruso non si limita alla mera lettura ma assume il controllo attivo di una sessione TCP già autenticata scavalcando il legittimo client, l'attacco prende il nome specialistico di **Connection Hijacking** o **Data Spoofing**.

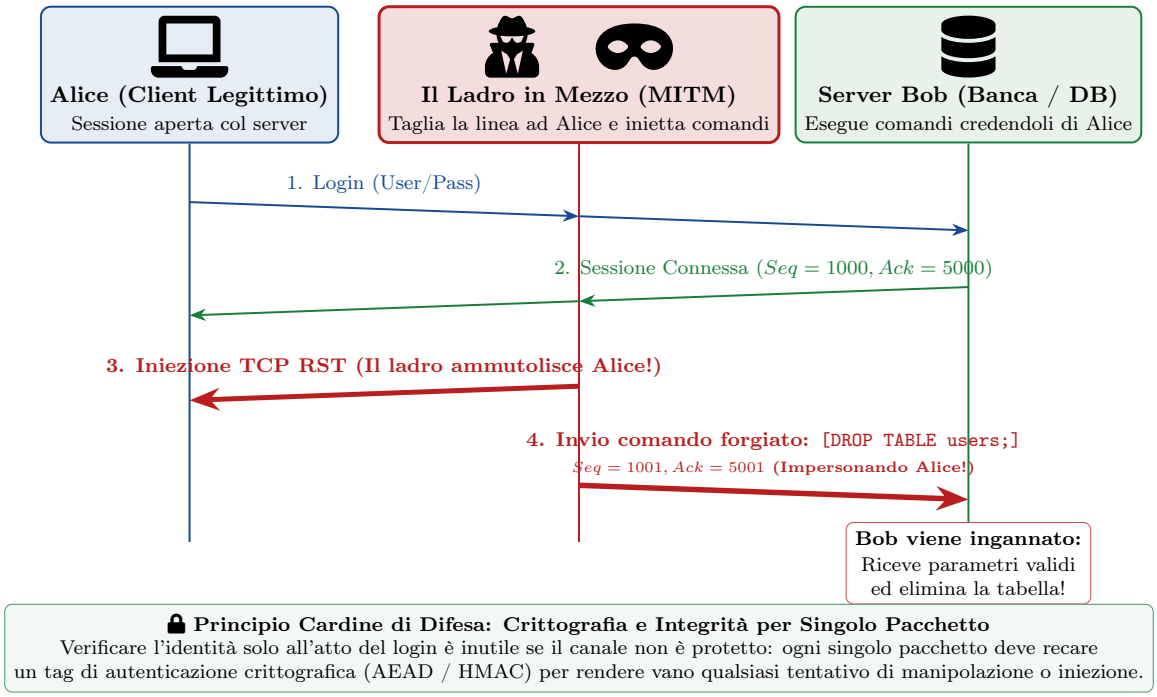


Figura 1.6: Dinamica operativa del Connection Hijacking: il ladro intercetta i numeri di sequenza, zittisce Alice con un TCP RST e invia comandi distruttivi a Bob a nome di lei.

Per contrastare efficacemente qualsiasi forma di Man-in-the-Middle o Connection Hijacking, il canale deve implementare simultaneamente quattro requisiti irrinunciabili:

1. **Riservatezza:** solo il destinatario autorizzato in possesso della chiave crittografica segreta può decifrare il payload.
2. **Autenticazione continua della controparte:** certezza costante dell'identità remota mediante credenziali e chiavi non forgiabili.
3. **Integrità dei dati:** calcolo di codici di controllo non manipolabili (**HMAC** o tag crittografici **AEAD**) su ogni singolo frammento.

4. **Serializzazione e Anti-Replay:** inclusione di identificativi univoci, *timestamp* o numeri di sequenza protetti crittograficamente per rilevare ed espellere frammenti duplicati, ritrasmessi o riordinati.

1.3.7 Malware

Il termine **malware** (*malicious software*) identifica genericamente qualsiasi programma sviluppato con l'intento malevolo di arrecare danni a un sistema, alterarne le funzioni, esfiltrare dati o consentirne il controllo remoto non autorizzato. La tassonomia classica (approfondita ampiamente da Stallings nel Capitolo 6 di *Computer Security*) distingue le seguenti classi fondamentali:

- **Virus:** porzione di codice malevolo non autonoma, progettata per replicarsi inserendosi all'interno di altri programmi eseguibili o documenti ospitanti. Per propagarsi richiede l'azione attiva e involontaria dell'utente (esecuzione di file infetti, disabilitazione delle protezioni, esecuzione di software piratato).
- **Worm:** programma malevolo completamente autonomo, il cui scopo primario consiste nell'autoridistribuzione attraverso la rete verso il maggior numero possibile di nodi bersaglio. A differenza del virus, il worm non richiede alcun intervento umano: sfrutta falle di sicurezza nei protocolli o servizi esposti per penetrare la memoria, infettare l'host e avviare nuove scansioni di rete, provocando gravi danni da saturazione della banda e delle risorse (come avvenuto nelle storiche epidemie dei worm Morris, Code Red, SQL Slammer e **SOBER**).
- **Backdoor:** canale di accesso segreto e non documentato che consente di oltrepassare i normali meccanismi di autenticazione del sistema. Può essere impiantata deliberatamente dal fornitore per agevolare attività di teleassistenza o aggiornamenti firmware non notificati (prassi ad alto rischio), oppure essere installata come secondo stadio di un'infezione trojan.
- **Trojan (o Cavallo di Troia):** programma che simula funzionalità utili o innocue (un'utilità di sistema, un visualizzatore di documenti, un gioco) celando al proprio interno un modulo malevolo distruttivo. È la principale tecnica per aprire un varco iniziale (*initial compromise*) negli endpoint individuali degli utenti, rimanendo silente per lunghi periodi prima di attivare backdoor o iniettare bot di rete.
- **Rootkit:** insieme di strumenti software e driver specializzati progettati per occultare la presenza di processi malevoli, file, porte aperte e chiavi di registro a livello di kernel o di sistema operativo, garantendo all'intruso l'amministrazione remota e persistente con i massimi privilegi.

I malware continuano ad essere incredibilmente letali perché fanno leva sull'anello debole della catena di sicurezza: il **fattore umano**. Le misure di contrasto esigono una rigorosa configurazione restrittiva dei privilegi di esecuzione, l'isolamento in sandbox dei contenuti e l'applicazione tempestiva degli aggiornamenti di sicurezza.

1.3.8 Ransomware

Il **ransomware** è una delle minacce più devastanti e remunerative dell'era digitale. Si tratta di una variante di malware che penetra all'interno di un sistema e applica una robusta crittografia simmetrica e asimmetrica (come AES-256 e RSA-4096) sull'intero archivio documentale o sui file di database della vittima, cancellando le copie shadow e richiedendo un riscatto in criptovalute non tracciabili (quali Bitcoin o Monero) per la fornitura della chiave di decifratura. Per accrescere la pressione coercitiva, gli attaccanti simulano spesso comunicazioni delle forze dell'ordine o minacciano il rilascio pubblico dei dati sul dark web: il paradigma della **Doppia Estorsione** (*cifratura più esfiltrazione preventiva*).

Ransomware vs Organizzazione e Gestione dei Backup: Nelle organizzazioni complesse è prassi universale predisporre copie di sicurezza periodiche (*backup*) per tutelare i dati critici. Tuttavia, il ripristino post-incidente presenta gravissime criticità:

- **Ransomware Silente (Latente):** gli attaccanti più evoluti programmano il malware per rimanere silente all'interno dei sistemi per diverse settimane o mesi prima di avviare la cifratura. Durante questo intervallo di latenza, i sistemi di backup aziendali salvano regolarmente copie contenenti il codice dormiente. Quando l'azienda viene colpita e ripristina il backup, il malware si riattiva dopo poco tempo, causando una nuova compromissione ciclica.
- **Cifratura dei Backup di Rete e Cloud:** il ransomware è programmato per percorrere le condivisioni di rete (condivisioni SMB/NFS) e sincronizzarsi con i bucket di storage cloud accessibili dall'host compromesso, cifrando simultaneamente le copie di sicurezza collegate.
- **Necessità di Backup Offline (Air-Gapped):** l'unica protezione autentica risiede nella **regola del 3-2-1** e nell'impiego di supporti disconnessi fisicamente dalla rete (*offline backup*), quali nastri magnetici o dischi isolati, immuni alla cifratura remota.

A questo proposito, la storia della gestione dei backup registra due casi emblematici evidenziati a lezione:

- **Il caso dell'organizzazione svedese:** un'istituzione conservava le copie di sicurezza su supporti a nastro magnetico, che venivano trasportati manualmente in un archivio sicuro situato in un edificio separato. Durante il trasporto in pieno inverno, l'incaricato appoggiava regolarmente i nastri sui sedili riscaldati dell'autovettura: l'elevato gradiente termico distrusse irreversibilmente la pellicola magnetica. L'azienda scoprì il danno solo quando fu necessario tentare un ripristino d'emergenza, constatando che in dieci anni nessuno aveva mai collaudato le procedure di recupero.
- **Il caso dell'archivio televisivo:** un'infezione rimasta latente per un tempo talmente prolungato da sovrascrivere l'intero ciclo di rotazione dei backup, compromettendo irrimediabilmente decenni di produzione audiovisiva storica.

L'assioma fondamentale della difesa è categorico: **un backup di cui non viene testata periodicamente la procedura di ripristino (restore test) equivale all'assenza totale di backup**.

1.3.9 Industria del Cybercrime

La proliferazione delle minacce ha alimentato una vera e propria industria criminale globale, strutturata come una **supply chain specializzata** e operante secondo il modello di business del **Crime-as-a-Service (CaaS)**:

- Sviluppatori di exploit e broker che individuano vulnerabilità **Zero-Day** e le vendono all'asta sul dark web;
- Fornitori di piattaforme di *Ransomware-as-a-Service* (RaaS), che concedono in affitto l'infrastruttura di cifratura a gruppi affiliati trattenendo una percentuale (generalmente il 20–30%) sui riscatti riscossi;
- Gestori di botnet dedicati all'erogazione di servizi DDoS a pagamento;
- Call center fraudolenti impiegati per condurre attacchi di ingegneria sociale o carpire codici OTP a due fattori;
- Reti di **Money Mules**: individui reclutati per compiere operazioni di riciclaggio. Quando gli aggressori sottraggono fondi tramite bonifici bancari illeciti, li frammentano su conti correnti intestati a intermediari, i quali prelevano immediatamente il contante presso sportelli fisici prima che parta il blocco bancario, rendendo le somme non tracciabili.

Questo modello industriale consente ad attori privi di competenze informatiche di acquistare pacchetti di attacco chiavi in mano, democratizzando l'accesso alla criminalità cibernetica e moltiplicando la frequenza delle aggressioni su scala planetaria.

—

1.4 Altri problemi e minacce

Nel contesto della cybersecurity, l'essere umano rappresenta universalmente l'elemento più vulnerabile della catena difensiva. Nonostante la complessità e l'efficacia dei meccanismi tecnologici (crittografia avanzata, firewall, IDPS), la sicurezza complessiva dipende ineludibilmente dalla disciplina comportamentale degli operatori, degli sviluppatori e degli utenti finali. Le principali aree in cui gli errori umani producono impatti devastanti comprendono:

- **Abuso e gestione impropria delle credenziali:** adozione di password deboli o banali, riutilizzo delle stesse credenziali su servizi molteplici e vulnerabilità al **Credential Stuffing** (scansione automatica di liste di coppie username/password sottratte in altri data breach per forzare portali aziendali).
- **Azioni sociali:** manipolazione psicologica (phishing, vishing, pretexting) finalizzata a estorcere accessi o forzare trasferimenti bancari.
- **Errori di configurazione:** dimenticanza di permessi restrittivi, pubblicazione di file di configurazione con chiavi crittografiche su repository pubblici (come GitHub) e mancata esecuzione degli aggiornamenti.
- **Esecuzione involontaria di malware:** apertura distratta di allegati di posta elettronica ingannevoli o collegamento di supporti di memoria rimovibili non verificati.

1.4.1 Alcuni esempi di attacchi riconducibili a errori umani

L'analisi retrospettiva di incidenti reali documenta come decisioni incaute e prassi sciatte abbiano aperto varchi fatali:

Caso di Studio 1: Wind Infostrada (Ottobre 2017) e Deutsche Telekom (2016) Nei primi giorni di ottobre 2017, decine di migliaia di modem/router domestici forniti dall'operatore telefonico italiano Wind Infostrada ai clienti con connettività in fibra risultarono improvvisamente **bricked** (ovvero resi completamente inerti e inutilizzabili, con hardware bloccato in modo irreversibile). L'origine del disastro risiedeva in un clamoroso errore di configurazione: per permettere l'assistenza tecnica remota e la gestione degli apparati, i router erano stati consegnati con la porta **Telnet (porta 8023 o 23)** aperta e direttamente esposta su Internet, protetta dalle credenziali predefinite di fabbrica (`admin/admin`). Il malware *BrickerBot* scansionò automaticamente la rete, effettuò il login Telnet e sovrascrisse la memoria flash dei router con sequenze casuali, distruggendo permanentemente il firmware. Un episodio del tutto speculare aveva coinvolto nel 2016 centinaia di migliaia di router Deutsche Telekom bersagliati sulla porta di telegestione TR-069. La contromisura strutturale risiede nella totale disabilitazione dei protocolli legacy in chiaro come Telnet a favore di protocolli crittografati sicuri (SSH/VPN), nell'imposizione di password uniche generate casualmente per ciascun apparato e nell'attivazione di sistemi di autenticazione a più fattori.

Caso di Studio 2: I Mercatini di Peshawar (2009) Nel 2009, presso i mercatini rionali di Peshawar, città pakistana al confine con l'Afghanistan, vennero messi in vendita da commercianti locali diversi computer portatili appartenuti ai Marine degli Stati Uniti impegnati in operazioni militari. Gli apparati contenevano mappe operative, schede di intelligence e comunicazioni strategiche classificate. I calcolatori, smarriti o sottratti durante missioni campali, erano completamente privi di qualsiasi forma di crittografia per la protezione dei **dati a riposo (Data at Rest)**: bastò rimuovere i dischi rigidi e collegarli a un secondo computer per estrarre integralmente l'archivio militare. L'episodio dimostra come l'assenza di cifratura integrale del disco (mediante

tecnologie quali BitLocker o LUKS) e di procedure di cancellazione o autodistruzione remota annulli interamente il valore strategico della difesa.

1.4.2 Ingegneria sociale

L'ingegneria sociale è l'arte della manipolazione psicologica volta a indurre gli individui a compiere azioni imprudenti o a rivelare informazioni riservate sfruttando inclinazioni umane naturali quali la fiducia, il timore dell'autorità, l'urgenza o la curiosità:

- **Phishing:** invio indiscriminato e massivo di comunicazioni ingannevoli che simulano l'identità visiva di istituti bancari o enti noti per carpire credenziali o recapitare allegati malevoli.
- **Spear Phishing:** attacco altamente mirato e personalizzato contro uno specifico dipendente, costruito raccogliendo preventivamente dettagli sul suo ruolo, sui fornitori aziendali e sui progetti in corso.
- **Whaling:** variante dello spear phishing indirizzata esclusivamente a figure dirigenziali di vertice (*CEO, CFO*), simulando emergenze legali, controversie tributarie o accordi societari riservati.
- **Pretexting:** creazione di uno scenario e di un pretesto narrativo estremamente plausibile per giustificare una richiesta anomala di dati o credenziali (ad esempio spacciandosi telefonicamente per un tecnico del supporto IT della sede centrale o un funzionario dell'istituto di credito).
- **Baiting:** offerta ingannevole di un bene materiale appetibile (ad esempio chiavette USB abbandonate deliberatamente nel parcheggio dell'azienda con etichette accattivanti quali *"Stipendi Dirigenti 2026"*) per indurre la vittima a collegarle alla propria postazione di lavoro.

Caso di Studio 3: Il Caso Confindustria (2017) Nel 2017, la sede di Confindustria a Bruxelles fu vittima di una devastante frode telematica da 500.000 euro riconducibile al modello del **Business Email Compromise (BEC)**. I truffatori compromisero o falsificarono la casella email di un fornitore storico dell'associazione e inviarono una richiesta urgente di liquidazione fattura, indicando le coordinate IBAN di un nuovo conto corrente aperto presso un paradiso fiscale. I criminali cronometrarono l'attacco approfittando dell'impegno del direttore in una trasferta: il personale amministrativo, intimorito dall'urgenza e ingannato dalla perfetta imitazione dello stile comunicativo, eseguì il bonifico senza operare una verifica telefonica fuori banda (*out-of-band verification*).

Caso di Studio 4: Phishing Transformers 3 alla Base Aerea di Andersen (Guam, 2010) Nel 2010, il comando della base aerea strategica statunitense di Andersen condusse un test interno di sicurezza inviando ai militari email che annunciavano le riprese sull'isola del colossal cinematografico *Transformers 3*, invitandoli a registrarsi come comparse su un sito clone per carpire credenziali militari. L'esperimento ebbe successo travolgente ma sfuggì al controllo operativo: i destinatari condivisero entusiasticamente l'informazione sui social network e con le testate giornalistiche locali, scatenando un'ondata di clamore mediatico che costrinse i vertici delle forze armate a rilasciare imbarazzate smentite ufficiali.

1.4.3 Attacchi famosi

La storia della cybersecurity registra alcune pietre miliari che hanno ridefinito la natura stessa dei conflitti moderni:

Stuxnet (2009–2010): Considerato la prima vera arma cibernetica di livello militare documentata nella storia. Sviluppato congiuntamente da agenzie governative statunitensi e israeliane nell'ambito dell'operazione *Olympic Games*, Stuxnet fu specificamente progettato per sabotare

fisicamente le centrifughe per l'arricchimento dell'uranio della centrale nucleare iraniana di Natanz. Introdotto tramite supporti USB infetti per scavalcare l'isolamento fisico della rete (*air-gapped*), il worm sfruttava ben **cinque vulnerabilità Zero-Day** distinte e incorporava certificati digitali rubati a legittimi produttori hardware (Realtek e JMicron). Il malware si attivava unicamente qualora rilevasse la presenza di specifici controllori logici programmabili (**PLC Siemens Step-7**) collegati a convertitori di frequenza; una volta identificato il target, alterava periodicamente la velocità di rotazione delle centrifughe provocandone il cedimento meccanico per risonanza, mentre inviava segnali di normale funzionamento ai monitor degli operatori umani per mascherare l'intrusione.

Brutal Kangaroo (2017): Framework operativo sviluppato dalla CIA (divulgato dai leak *Vault 7* di WikiLeaks) progettato per penetrare reti informatiche isolate fisicamente da Internet (**sistemi air-gapped**). Il payload infetta una postazione connessa (*Primary Host*); quando l'operatore inserisce una chiavetta USB, il malware vi deposita un modulo secondario denominato *Drifting Deadline*, sfruttando vulnerabilità dell'interprete delle icone o dei link di Windows per eseguirsi all'inserimento del supporto nel PC isolato ed esfiltrare dati tramite canali steganografici.

BlackEnergy (2015): Trojan modulare impiegato dal gruppo criminale *Sandworm* (collegato ai servizi di intelligence russi) per sferrare il primo attacco cibernetico della storia contro una rete elettrica nazionale civile. Nel dicembre 2015, l'infezione veicolata tramite spear phishing compromise i centri di controllo **SCADA/ICS** di tre distributori di energia in Ucraina, provocando il blackout al buio e al gelo di oltre 230.000 cittadini per svariate ore. BlackEnergy costituisce l'archetipo dell'**Advanced Persistent Threat (APT)**: attori statali altamente strutturati che conducono operazioni invisibili e protratte nel tempo.

Mirai (2016): Botnet che ha segnato una svolta epocale nell'impiego offensivo dell'Internet of Things. Mirai scansionò ininterrottamente le porte Telnet di milioni di dispositivi embedded (telecamere di videosorveglianza, baby monitor, router domestici basati su processori con architettura ARC eseguenti distribuzioni ridotte di Linux), effettuando l'accesso con una banale lista di 60 combinazioni di credenziali di fabbrica predefinite (`root/admin`, `admin/admin`). Una volta assoldati oltre 100.000 nodi zombie, l'attacco generò volumi record di traffico DDoS contro il blog investigativo *Krebs on Security* (620 Gbps) e il provider DNS *Dyn*, provocando l'inaccessibilità simultanea di Twitter, Netflix, Reddit, Spotify e Amazon in tutto il Nord America.

BlueBorne (2017): Insieme di vulnerabilità zero-day relative allo stack del protocollo **Bluetooth** presente nei sistemi operativi Android, iOS, Windows e Linux. La particolarità devastante di BlueBorne risiede nel fatto che non richiede alcun accoppiamento preventivo (*pairing*) né la visibilità del dispositivo: è sufficiente che l'interfaccia radio Bluetooth sia accesa affinché un aggressore nel raggio di 10 metri possa eseguire codice arbitrario con privilegi di kernel tramite buffer overflow, assumendo il controllo totale del sistema. La vulnerabilità ha colpito pesantemente i sistemi di *infotainment* delle automobili connesse (esponendo al rischio di manipolazione il bus interno **CAN-bus** dei veicoli, celebre vulnerabilità già dimostrata sperimentalmente nel controllo remoto dei freni di una *Jeep Cherokee*), dimostrando la convergenza critica tra sicurezza informatica (*security*) e incolumità fisica (*safety*).

—

1.5 Sicurezza: definizioni

La sicurezza informatica è l'insieme dei processi, delle tecnologie e delle politiche che mirano a proteggere le informazioni e i sistemi informatici da accessi non autorizzati, alterazioni, distruzioni

o interruzioni dei servizi. L'obiettivo primario è ridurre i rischi entro limiti accettabili per l'organizzazione, garantendo le proprietà canoniche che caratterizzano i sistemi affidabili.

1.5.1 Riservatezza

La **riservatezza** (*Confidentiality*) è la proprietà che assicura che le informazioni siano accessibili esclusivamente a soggetti, entità o processi esplicitamente autorizzati, prevenendo la divulgazione o l'esposizione accidentale o malevola dei dati a terze parti. Tale proprietà si applica sia ai dati digitali trasmessi in rete o archiviati sui supporti di memoria, sia alle informazioni personali sensibili (dati sanitari, biometrici, convinzioni religiose o politiche).

La riservatezza viene garantita mediante un insieme integrato di misure tecniche (algoritmi di cifratura simmetrica AES-GCM o asimmetrica RSA/ECC, canali cifrati TLS) e organizzative (controllo degli accessi, segmentazione delle autorizzazioni).

È fondamentale sottolineare la distinzione concettuale tra **riservatezza** e **privacy**:

- La *riservatezza* è una proprietà tecnica e oggettiva del dato: fa sì che occhi indiscreti non possano leggere il testo in chiaro.
- La *privacy* è un diritto giuridico e soggettivo della persona fisica (disciplinato da normative quali il **GDPR**): definisce la legittimità, le finalità e i limiti entro cui un'organizzazione può raccogliere, conservare, elaborare e profilare i dati personali degli individui.

1.5.2 Integrità

L'**integrità** (*Integrity*) assicura che le informazioni e i sistemi rimangano corretti, completi e coerenti nel tempo, al riparo da modifiche arbitrarie, cancellazioni o manomissioni non autorizzate. Nel contesto delle comunicazioni di rete, essa impone che il destinatario riceva esattamente la sequenza di bit emessa dal mittente, senza alcuna alterazione intermedia, omissione o duplicazione fraudolenta (*attacchi di replay*).

L'integrità viene garantita mediante strumenti matematici calcolati sul messaggio:

- **Funzioni Crittografiche di Hash (SHA-256, SHA-3):** mappano una stringa di lunghezza arbitraria in un'impronta digitale (*digest*) di dimensione fissa, godendo delle proprietà di resistenza alla pre-immagine e alle collisioni.
- **Codici MAC (Message Authentication Code) e Firme Digitali:** garantiscono l'integrità coniugandola con l'autenticazione dell'origine del dato mediante chiavi segrete o chiavi private asimmetriche.

Le omissioni e le duplicazioni dei pacchetti vengono invece neutralizzate mediante una rigorosa **numerazione progressiva** (serializzazione) integrata nei tag di autenticazione crittografica.

1.5.3 Autenticazione della controparte

L'**autenticazione dell'entità** (*Entity Authentication*) è il processo mediante il quale un'entità verifica l'identità dichiarata di un'altra controparte con cui si appresta a comunicare. L'autenticazione può configurarsi come:

- **Singola (unilaterale):** in cui una sola delle due parti verifica l'identità dell'altra (come accade ordinariamente in HTTPS, dove il client verifica il certificato X.509 del server web, mentre il client rimane anonimo a livello di connessione);
- **Mutua (bilaterale):** in cui entrambe le entità accertano reciprocamente la rispettiva identità (come nei canali VPN IPsec o in TLS con autenticazione mediante certificati client).

I meccanismi di autenticazione si fondano sull'impiego combinato di uno o più **fattori di autenticazione**:

1. *Qualcosa che l'utente conosce (Knowledge):* password alfanumerica, PIN o passphrase segreta;

2. *Qualcosa che l'utente possiede (Possession):* token hardware OTP, smart card crittografica, smartphone abilitato;
3. *Qualcosa che l'utente è (Inherence):* caratteristiche biometriche uniche, quali impronte digitali, scansione dell'iride o geometria facciale.

L'integrazione di almeno due fattori distinti costituisce l'**Autenticazione a più fattori** (**MFA**), baluardo essenziale contro il furto delle credenziali.

1.5.4 Autenticazione dei dati

L'**autenticazione dei dati** (*Data Origin Authentication*) è la proprietà che certifica che il messaggio provenga effettivamente dall'autore dichiarato e non sia stato forgiato o manipolato da terzi. Tale proprietà è indissolubilmente correlata all'integrità: non avrebbe alcun senso logico attestare l'origine di un documento se il suo contenuto potesse essere alterato durante il transito.

Gli strumenti matematici fondamentali per conseguire l'autenticazione dei dati sono i codici **HMAC** (in contesti a chiave simmetrica condivisa) e le **firme digitali** (in contesti asimmetrici con coppia di chiavi pubblica/privata). L'autenticazione dei dati deve essere applicata sistematicamente a ogni singolo pacchetto di una sessione di rete attiva, al fine di impedire l'intromissione di attacchi MITM o iniezioni di comando successive all'handshake iniziale.

1.5.5 Non ripudio

Il **non ripudio** (*Non-Repudiation*) è la proprietà che impedisce a un soggetto o ad un'entità di negare a posteriori di aver compiuto una determinata azione, sottoscritto un accordo o emesso uno specifico messaggio. Questa caratteristica conferisce pieno **valore probatorio e legale** alle transazioni elettroniche, ai bonifici bancari e alla contrattualistica informatica.

A differenza della riservatezza e dell'integrità, il non ripudio non può essere garantito dalla crittografia simmetrica o dagli HMAC: poiché la chiave simmetrica è nota ad entrambe le parti (A e B), Bob potrebbe benissimo fabbricare un messaggio spacciandolo per proveniente da Alice. Il non ripudio esige **esclusivamente l'adozione della firma digitale asimmetrica**, generata mediante la chiave privata detenuta in via esclusiva dal mittente. Inoltre, il non ripudio esige requisiti giuridici e di interfaccia: l'utente deve operare in condizioni di piena consapevolezza dell'atto compiuto, imponendo che le interfacce grafiche (UI) non contengano ambiguità, inganni o pulsanti fuorvianti suscettibili di viziare il consenso legale.

1.5.6 Autorizzazione (o controllo degli accessi)

L'**autorizzazione** (*Authorization*) è il processo mediante il quale il sistema informativo stabilisce quali specifiche operazioni (lettura, scrittura, cancellazione, esecuzione) un soggetto identificato o un processo possa eseguire su una determinata risorsa protetta. Il modello concettuale originario prevede un'immensa **matrice di controllo degli accessi** (*Access Control Matrix*), le cui righe identificano i soggetti (utenti/processi), le colonne gli oggetti (file/servizi) e le celle contengono i diritti concessi.

Poiché la gestione diretta della matrice risulta impraticabile nei sistemi distribuiti, la letteratura scientifica ha formalizzato cinque paradigmi di riferimento:

- **Role-Based Access Control (RBAC):** i privilegi vengono associati a ruoli operativi aziendali (es. Amministratore, Analista, Tecnico) e gli utenti vengono semplicemente assegnati a tali ruoli, semplificando la revoca e il controllo centralizzato delle autorizzazioni.
- **Identity-Based Access Control (IBAC):** i permessi vengono assegnati direttamente ai singoli identificativi utente; è un modello semplice ma del tutto inadatto alla scalabilità d'impresa.

- **Attribute-Based Access Control (ABAC):** le decisioni di accesso sono valutate dinamicamente analizzando un insieme di attributi del soggetto (reparto, anzianità), della risorsa (livello di riservatezza) e del contesto operativo (orario di connessione, indirizzo IP, localizzazione geografica).
- **Relationship-Based Access Control (ReBAC):** le autorizzazioni discendono dalle relazioni topologiche intercorrenti tra i soggetti, modello tipicamente adottato dai social network e dalle piattaforme collaborative (es. visibilità limitata a contatti diretti o colleghi di team).
- **Mandatory Access Control (MAC):** l'accesso è governato in modo rigido e centralizzato dal sistema operativo attraverso regole matematiche cablate (*hardcoded*) basate su etichette di sicurezza e livelli gerarchici di riservatezza (Riservato, Segreto, Top Secret), come nei modelli militari Bell-LaPadula; l'utente proprietario della risorsa non ha la facoltà di alterarne o cederne i diritti.

1.5.7 Protezione dei dati

La protezione dei dati comprende l'insieme coordinato delle misure tecnologiche, architetturali e organizzative volte a preservare riservatezza, integrità e disponibilità del patrimonio informativo lungo l'intero ciclo di vita del dato, distinguendo chiaramente i tre stati fondamentali del dato:

1. **Data in Transit (Dati in Movimento):** informazioni che attraversano canali di rete pubblici o privati, protette mediante suite crittografiche robuste (TLS, IPsec).
2. **Data at Rest (Dati a Riposo):** informazioni memorizzate permanentemente su supporti di memoria di massa (hard disk, nastri magnetici, database, storage cloud), tutelate mediante crittografia di blocco (AES-XTS) e segregazione delle chiavi crittografiche all'interno di moduli hardware protetti (**HSM** / TPM).
3. **Data in Use / Data in Memory (Dati in Uso):** informazioni allocate all'interno della memoria volatile (RAM, registri CPU) durante l'elaborazione attiva da parte dei processi, protette mediante enclavi di esecuzione sicura (*Confidential Computing*, Intel SGX, AMD SEV) e azzeramento immediato dei buffer dopo l'utilizzo.

—

1.6 Principi di sicurezza

I principi di sicurezza rappresentano le linee guida architetturali fondamentali per orientare correttamente la progettazione e la gestione di sistemi affidabili:

- **Security by Design:** prescrive di considerare e integrare i requisiti di sicurezza sin dalle fasi concettuali e architetturali embrionali del sistema. Le misure difensive non devono costituire correttivi posticci sovrapposti a posteriori, ma devono essere parte integrante delle strutture dati, delle interfacce applicative e del ciclo di sviluppo (*DevSecOps*).
- **Security by Default:** stabilisce che qualsiasi apparato, sistema operativo o applicazione debba presentarsi al momento dell'installazione con la configurazione più restrittiva e protetta possibile. I servizi non indispensabili devono essere disabilitati, le credenziali predefinite bandite e le porte chiuse. Qualsiasi allentamento delle restrizioni operative richiede un'azione esplicita e consapevole da parte dell'amministratore, responsabilizzandone la scelta.
- **Defense-in-Depth** (*Defense in Depth* o Difesa in Profondità): principio di derivazione militare secondo cui la sicurezza non deve mai dipendere da una singola barriera difensiva. L'infrastruttura deve essere organizzata secondo cerchi concentrici di protezione (firewall perimetrali, segmentazione in DMZ, autenticazione a due fattori, crittografia dei dischi, rilevamento delle intrusioni IDPS): se un attaccante scavalca un livello protettivo, troverà immediatamente una barriera successiva a bloccarne la progressione laterale.

- **Principio di Kerckhoffs:** pilastro della crittografia moderna formulato da Auguste Kerckhoffs nel 1883, secondo cui la sicurezza di un sistema crittografico deve dipendere esclusivamente dalla segretezza della chiave e mai dalla segretezza dell'algoritmo impiegato. La cosiddetta *Security through Obscurity* (sicurezza attraverso l'occultamento dei meccanismi) è un'illusione fatale: gli algoritmi devono essere pubblici e collaudati dalla comunità scientifica internazionale.
- **Need-to-Know:** principio emanato dal **NIST** che impone che ciascun operatore possa accedere unicamente ed esclusivamente alle informazioni e ai documenti strettamente necessari per svolgere la propria mansione corrente, riducendo al minimo l'esposizione di dati confidenziali.
- **Least Privilege (Minimo Privilegio):** prescrive che qualsiasi utente, account di servizio o processo debba operare disponendo unicamente dei privilegi operativi minimi e temporali strettamente indispensabili per completare l'operazione richiesta, confinando tempestivamente l'impatto di un'eventuale compromissione.

—

1.7 I tre pilastri della sicurezza

La gestione della sicurezza informatica non si configura come un progetto statico dotato di una data di conclusione, bensì come un **ciclo operativo continuo e ricorsivo**, in accordo con la celeberrima massima enunciata da **Bruce Schneier**:

> *"Security is a process, not a product."*
> (*"La sicurezza è un processo, non un prodotto."*)

Un'organizzazione che acquisti prodotti tecnologici all'avanguardia ma trascuri il monitoraggio, l'aggiornamento e la revisione delle procedure è destinata a soccombere.

Per strutturare metodologicamente le attività operative, l'approccio classico suddivide il ciclo di gestione in una fase preliminare di pianificazione e in tre pilastri consecutivi:

1. **Fase Preliminare di Pianificazione (Planning):** momento in cui l'organizzazione conduce l'analisi e la valutazione dei rischi (*Risk Assessment*), definisce le politiche di sicurezza aziendali, identifica gli asset critici e fissa gli obiettivi di conformità normativa (**NIST Cybersecurity Framework**, ISO/IEC 27001).
2. **Pilastro 1: Avoidance (Prevenzione):** implementazione di controlli proattivi per minimizzare la probabilità di accadimento delle minacce e restringere la superficie d'attacco (firewall, cifratura end-to-end, segmentazione in VLAN, hardening dei server, formazione continua del personale). La prevenzione riduce il rischio ma non lo azzera: l'errore umano o uno zero-day possono sempre perforare le difese perimetrali.
3. **Pilastro 2: Detection (Rilevamento):** monitoraggio continuo e in tempo reale dell'infrastruttura per identificare tempestivamente le violazioni che hanno eluso la fase di prevenzione. Si avvale di sistemi IDPS, piattaforme SIEM/SOC, analisi dei log e rilevamento delle anomalie comportamentali.
4. **Pilastro 3: Investigation (Analisi e Risposta):** attività di *Incident Response* e analisi forense digitale (*Digital Forensics*) per comprendere la dinamica dell'intrusione, quantificare l'esfiltrazione dei dati, bonificare i sistemi compromessi e raccogliere evidenze con valore probatorio legale per l'avvio delle azioni giudiziarie contro i perpetratori.

Le risultanze dell'indagine alimentano nuovamente la fase di pianificazione, aggiornando le difese in un ciclo di miglioramento continuo (*Plan-Do-Check-Act*).

Capitolo 2

Gestione dei rischi informatici

La gestione del rischio informatico (*Risk Management*) si configura come un'attività essenziale in ogni azienda, con l'obiettivo primario di quantificare i rischi e ridurli entro limiti tollerabili tramite l'applicazione di un processo ripetibile e oggettivo. Questo approccio metodologico è necessario per minimizzare i costi diretti e indiretti derivanti da incidenti e attacchi. Ma diventa indispensabile nel caso si fosse interessati ad aderire a standard (come la famiglia ISO/IEC 27000) e normative (come il GDPR, il regolamento europeo NIS2 o il Cyber Resilience Act) che richiedono esplicitamente un'analisi del rischio. Il processo deve essere il più possibile scientifico e rigoroso per evitare che la valutazione del rischio sia arbitraria o soggettiva e, in ultima istanza, inutile.

Nel contesto economico contemporaneo, le imprese dipendono in maniera totale e indissolubile dai propri asset digitali: dai database transazionali ai portali e-commerce, dai servizi esposti su Internet (come gateway VPN e interfacce API) fino ai sistemi di controllo industriale (SCADA/ICS). Di conseguenza, un'interruzione di servizio o un'esfiltrazione massiva di dati proprietari non produce esclusivamente un danno tecnologico circoscritto, bensì una compromissione diretta della continuità di business. Tuttavia, le risorse economiche e umane a disposizione di un'organizzazione sono intrinsecamente finite; risulta perciò materialmente impossibile proteggere ogni singolo componente informativo con il massimo livello di blindatura concepibile. La gestione del rischio assolve precisamente a questa funzione di razionalizzazione economica: stabilire scientificamente dove allocare le risorse di difesa affinché ogni euro investito produca la massima riduzione del danno atteso.

Inoltre, la conformità normativa e l'adozione di standard internazionali di sicurezza non costituiscono un mero adempimento burocratico, ma rappresentano veri e propri abilitatori di mercato. Nelle catene di fornitura globali (*supply chain*), le grandi organizzazioni e le pubbliche amministrazioni richiedono tassativamente ai propri partner commerciali e fornitori la certificazione ISO/IEC 27001 o la conformità a quadri di controllo rigorosi; l'assenza di un comprovato processo di risk management prefigura l'esclusione automatica da ampie fette di mercato. Parimenti, normative vincolanti come l'Articolo 32 del Regolamento Generale sulla Protezione dei Dati (GDPR, Regolamento UE 2016/679) impongono al titolare e al responsabile del trattamento di mettere in atto misure tecniche e organizzative adeguate a garantire un livello di sicurezza commisurato al rischio, comminando sanzioni pecuniarie che possono raggiungere il 4% del fatturato globale annuo in caso di negligenza strutturale.

2.1 Fondamenti e terminologia del rischio

Il processo di gestione del rischio richiede la precisa definizione e distinzione dei seguenti elementi:

- **Asset:** qualsiasi risorsa che abbia valore per l'azienda e sia necessaria all'erogazione di un servizio IT, inclusi beni materiali (es. server fisici, dispositivi di rete, apparati storage,

workstation, linee di produzione connesse) e beni immateriali (es. reputazione aziendale, brand value, proprietà intellettuale, quotazione in borsa, fiducia dei clienti, segreti industriali e dati personali dei dipendenti e degli utenti).

- **Debolezza (*Weakness*):** una predisposizione del sistema a manifestare problemi, come codice scritto male, configurazione non attenta, assenza di controlli di convalida sull'input, mancata cifratura dei canali ausiliari, o codice generato tramite modelli di intelligenza artificiale integrato nell'ambiente di produzione senza preventiva revisione tecnica. Una debolezza rappresenta un difetto latente che non si traduce necessariamente in una vulnerabilità direttamente exploitabile, ma che costituisce il presupposto strutturale affinché un'esposizione emerga.
- **Vulnerabilità (*Vulnerability*):** una debolezza scoperta e sfruttabile direttamente dagli attaccanti per violare le proprietà di sicurezza (Confidenzialità, Integrità, Disponibilità, Autenticazione, Non ripudio) di un sistema o di una rete informatica.
- **Minaccia (*Threat*):** un evento (intenzionale o accidentale) che, se sfruttato, può causare la perdita di una o più proprietà di sicurezza (es. Confidenzialità, Integrità, Disponibilità). La minaccia è spesso associata a una sorgente di minaccia (*Threat Agent*), caratterizzata da specifiche motivazioni, competenze tecniche, risorse operative e budget economico.
- **Attacco:** il verificarsi di una minaccia di tipo intenzionale, posta in essere da un attore malevolo (avversario interno o esterno, cybercriminale, gruppo APT sponsorizzato da stati esteri, attivista o dipendente infedele) che persegue un obiettivo malevolo attraverso l'esecuzione di una sequenza di azioni ostili.
- **Evento Negativo:** il verificarsi di una minaccia di tipo accidentale (es. guasto hardware di un disco rigido, perdita di connettività per tranciamento di un cavo in fibra, incendio in sala server, errore umano di un amministratore di sistema durante una manutenzione o calamità naturale).

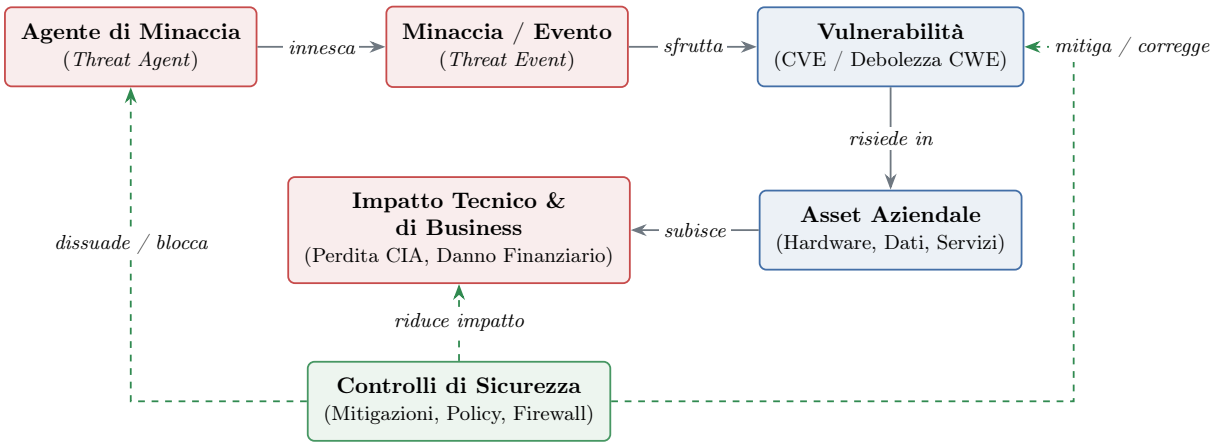


Figura 2.1: Modello ontologico delle relazioni tra i concetti fondamentali di rischio cibernetico (secondo NIST SP 800-30 e OWASP). L'Agente di Minaccia innesca un Evento che sfrutta una Vulnerabilità latente nell'Asset, provocando un Impatto avverso; i Controlli di Sicurezza agiscono spezzando la catena causale.

La corretta comprensione della relazione tra questi concetti è basilare per evitare gravi errori di valutazione metodologica. Non ogni debolezza presente nel codice o nell'architettura costituisce una vulnerabilità: una debolezza (*weakness*) rappresenta un difetto latente (come un buffer non controllato o la mancata sanitizzazione di un campo), ma diventa una vera e propria **vulnerabilità** soltanto se risulta esposta e direttamente sfruttabile da un vettore di attacco esterno o interno. Una debolezza in un modulo isolato e inaccessibile rimane catalogata come CWE ma non riceve un CVE con punteggio di exploitability finché non esiste una minaccia concreta che ne consenta

lo sfruttamento; tuttavia, trascurare l'eliminazione delle debolezze in fase di sviluppo espone l'infrastruttura alla trasformazione di tali difetti in vulnerabilità exploitabili non appena muta il contesto operativo o compaiono nuovi strumenti d'attacco.

2.2 Vulnerabilità e CVE – Common Vulnerabilities and Exposures

Le vulnerabilità di sicurezza informatica note e rese pubbliche sono descritte in modo standardizzato nel dizionario **Common Vulnerabilities and Exposures (CVE)**, mantenuto dalla **MITRE Corporation** e finanziato dalla Cybersecurity and Infrastructure Security Agency (CISA) del dipartimento della Homeland Security statunitense. Prima dell'introduzione dello standard CVE nel 1999, ogni produttore di software e ogni fornitore di strumenti di scansione antivirus o IDS utilizzava una propria nomenclatura proprietaria per indicare i medesimi difetti di sicurezza; tale frammentazione rendeva impossibile correlare i report di vulnerabilità tra strumenti eterogenei o tracciare in modo univoco lo stato di remediation all'interno di un'infrastruttura complessa.

I *CVE Record* sono pubblicati nella *CVE List* ufficiale dal *CVE Program* (`https://www.cve.org/`) tramite una rete decentralizzata di organizzazioni autorizzate denominate **CNA** (*CVE Numbering Authorities*), che includono i principali vendor di tecnologia (es. Microsoft, Red Hat, Apple, Google, Cisco), team di ricerca e coordinatori di sicurezza informatica. Successivamente, il **National Vulnerability Database (NVD)**, gestito dal NIST (`https://nvd.nist.gov/`), importa i record CVE e li arricchisce con analisi sistematiche di dettaglio, inclusa l'associazione alle debolezze CWE, la stima dei vettori e punteggi CVSS, e l'elenco delle configurazioni software affette (*Common Platform Enumeration* – CPE).

I record CVE riportano un insieme standard di attributi che servono a caratterizzarli:

- **CVE-ID:** ogni vulnerabilità ottiene un identificatore univoco globale (es. `CVE-2017-5754`), accompagnato da una descrizione testuale oggettiva dello stato di difetto e da una serie di collegamenti e riferimenti ipertestuali a bollettini dei vendor, advisory di sicurezza e proof-of-concept. L'identificatore è strutturato secondo una sintassi rigorosa: il prefisso fisso `CVE-`, seguito dall'anno a quattro cifre in cui la vulnerabilità è stata formalmente registrata o resa pubblica, e da una sequenza numerica arbitraria a lunghezza variabile di almeno quattro cifre (azzerata all'inizio di ciascun anno solare).
- **CVSS (*Common Vulnerability Scoring System*):** è un framework aperto e standardizzato, mantenuto dall'organizzazione non-profit **FIRST** (*Forum of Incident Response and Security Teams*), che genera un punteggio numerico continuo compreso nell'intervallo da **0.0 a 10.0** per quantificare la gravità intrinseca e il potenziale danno derivante dallo sfruttamento della vulnerabilità. La specifica ampiamente adottata negli ambienti aziendali è la versione **CVSS v3.1** (con la recente introduzione della specifica **CVSS v4.0**). Il calcolo del punteggio non è arbitrario ma si basa su formule matematiche deterministiche alimentate da tre gruppi distinti di metriche:
  1. **Metriche Base (*Base Score*):** rappresentano le caratteristiche intrinseche e costanti nel tempo e nello spazio della vulnerabilità. Si suddividono in due sotto-vettori:
     - *Metriche di Exploitability:* quantificano la facilità di accesso e attacco:
       - **Attack Vector (AV):** riflette il contesto da cui l'attacco può essere sferrato. Assume i valori: **Network (N)** (vulnerabilità sfruttabile da remoto via Internet senza vincoli di routing, massimo punteggio di gravità); **Adjacent (A)** (richiede accesso allo stesso dominio di broadcast o sottorete locale, es. attacchi ARP o Bluetooth); **Local (L)** (richiede accesso autenticato a una shell locale o esecuzione di codice sul target, come nelle privilege escalation); **Physical (P)** (richiede interazione fisica diretta con il dispositivo o le sue interfacce hardware).

        * **Attack Complexity (AC):** misura la presenza di condizioni operative non controllabili dall'attaccante (es. race condition complesse, dipendenza da specifici layout di memoria randomizzati da ASLR). Assume i valori **Low (L)** o **High (H)**.
        * **Privileges Required (PR):** livello di autorizzazione che l'attaccante deve possedere prima di lanciare l'exploit. Assume i valori **None (N)**, **Low (L)** (privilegi utente standard), o **High (H)** (privilegi amministrativi/root).
        * **User Interaction (UI):** misura se lo sfruttamento richiede l'intervento di un utente legittimo (es. apertura di un allegato malevolo in un attacco di phishing o click su un link ingannevole in un attacco CSRF). Assume i valori **None (N)** o **Required (R)**.
        * **Scope (S):** definisce se lo sfruttamento della vulnerabilità in un componente compromesso può avere impatto su risorse gestite da un'autorità di sicurezza differente (es. un container escape che consente di prendere il controllo dell'host sottostante, o una violazione di sandbox del browser). Assume i valori **Unchanged (U)** o **Changed (C)**. La transizione a *Changed* incrementa drasticamente il punteggio finale.
    - *Metriche di Impatto (Impact):* descrivono le conseguenze dirette del successo dell'attacco sulla triade di sicurezza:
        * **Confidentiality (C):** misura il grado di divulgazione non autorizzata di dati riservati (**None [N]**, **Low [L]**, **High [H]**).
        * **Integrity (I):** misura il livello di alterazione malevola o manomissione delle informazioni (**None [N]**, **Low [L]**, **High [H]**).
        * **Availability (A):** misura la perdita di disponibilità o l'interruzione del servizio (**None [N]**, **Low [L]**, **High [H]**).
2. **Metriche Temporali (*Temporal Score*):** misurano lo stato dinamico della vulnerabilità nel corso della sua evoluzione temporale, considerando la maturità del codice di exploit (*Exploit Code Maturity*: Not Defined, Unproven, Proof-of-Concept, Functional, High), lo stato della soluzione (*Remediation Level*: Official Fix, Temporary Fix, Workaround, Unavailable), e il grado di confidenza del report (*Report Confidence*).
3. **Metriche Ambientali (*Environmental Score*):** consentono al singolo analista aziendale di personalizzare il punteggio in relazione allo specifico contesto operativo dell'organizzazione, modificando i pesi delle metriche base in funzione della criticità locale degli asset protetti o applicando controlli di sicurezza compensativi esistenti.

I punteggi CVSS sono raggruppati in classi qualitative di severità (*Severity Ratings*):

- **None:** 0.0
- **Low:** $0.1 - 3.9$
- **Medium:** $4.0 - 6.9$
- **High:** $7.0 - 8.9$
- **Critical:** $9.0 - 10.0$

2.2.1 Classificazione temporale dello stato delle vulnerabilità

Sotto il profilo del ciclo di vita operativo e della gestione del rischio aziendale, le vulnerabilità sono classificate in due macro-stati:

1. **Vulnerabilità Non Note:** quando nessuno ne è a conoscenza oppure quando l'esistenza del difetto è nota esclusivamente a singoli ricercatori o attaccanti che la mantengono totalmente segreta senza alcuna traccia pubblica.
2. **Vulnerabilità Note:** vulnerabilità la cui esistenza è stata formalmente accertata. In questa categoria si opera una fondamentale specializzazione temporale:

- **Zero-Day:** l'intervallo temporale che decorre da quando la vulnerabilità viene scoperta (da un hacker malintenzionato, da un'agenzia governativa o da un ricercatore etico) fino al momento esatto in cui il fornitore ufficiale del software non sviluppa e rende pubblicamente accessibile una patch correttiva. In questa finestra non esiste alcuna contromisura diretta fornita dal vendor;
- **Unpatched:** l'intervallo temporale che decorre da quando la patch correttiva viene rilasciata e pubblicata dal vendor fino a quando essa non viene effettivamente installata e messa in produzione su ciascun dispositivo aziendale affetto;
- **Patched:** lo stato del sistema successivo alla corretta applicazione, collaudo e attivazione della patch, che ripristina la sicurezza del componente rendendo innocua la vulnerabilità.

Definizione Formale: Patch di Sicurezza

Una patch è una porzione di codice software o microcodice distribuita dal fornitore di un prodotto che, una volta applicata all'ambiente di esecuzione, modifica la logica o i file binari del sistema per eliminare un difetto o rendere innocua una vulnerabilità senza alterare le funzionalità legittime del programma.

2.3 CWE e window of exposure

La **CWE (Common Weakness Enumeration)** è una tassonomia formale e dizionario standard, gestito anch'esso dalla MITRE Corporation, che cataloga gli errori e le debolezze di programmazione, architettura, design, configurazione e implementazione hardware e software che possono manifestarsi nei sistemi digitali.

A differenza delle CVE, che identificano singole istanze specifiche di vulnerabilità riscontrate in versioni determinate di prodotti commerciali o open-source (es. la CVE-2021-44228 in Apache Log4j), la CWE si concentra sulla **categoria concettuale dell'errore astratto** (es. mancata validazione di input, buffer overflow, assenza di controllo di accesso). Le debolezze devono essere sistematicamente monitorate dai team di sviluppo e sicurezza poiché costituiscono il terreno fertile che può trasformarsi in vulnerabilità sfruttabili (CVE).

Tra gli esempi più rilevanti e diffusi di debolezza censiti nella tassonomia CWE figurano:

- **CWE-20 (Improper Input Validation):** il codice riceve dati dall'esterno senza verificarne esaustivamente la conformità rispetto a formati, lunghezze, intervalli numerici o caratteri ammessi. Costituisce la causa radice della maggioranza degli attacchi web;
- **CWE-79 (Improper Neutralization of Input During Web Page Generation — Cross-site Scripting):** mancata neutralizzazione di script malevoli iniettati nelle pagine web visualizzate dagli utenti;
- **CWE-89 (Improper Neutralization of Special Elements used in an SQL Command — SQL Injection):** inserimento di comandi SQL manipolati attraverso parametri di input non parametrizzati;
- **CWE-119 (Improper Restriction of Operations within the Bounds of a Memory Buffer):** manipolazione della memoria oltre i limiti allocati, tipica dei linguaggi non memory-safe come C e C++;
- **CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor):** rilascio o fuga di dati confidenziali a soggetti privi delle necessarie credenziali di accesso.

Non vi è alcuna certezza che una generica debolezza presente nel codice possa essere con successo trasformata in un exploit funzionante; tuttavia, eliminare le debolezze alla radice applicando principi di *Security by Design* e metodologie di *Secure Software Development Life Cycle* (SSDLC) rappresenta la strategia più economica ed efficace per anticipare l'insorgenza delle vulnerabilità.

2.3.1 Esempio di vulnerabilità critica: Meltdown (CVE-2017-5754)

Un esempio emblematico di vulnerabilità catalogata ad altissimo impatto sistemico è **Meltdown** (registrata come **CVE-2017-5754** da ricercatori indipendenti di Google Project Zero, Cyberus Technology e TU Graz alla fine del 2017 e resa pubblica nel gennaio 2018).

Questa vulnerabilità colpisce a livello hardware la quasi totalità dei microprocessori moderni (in particolare le architetture Intel x86 e x86-64 prodotte dal 1995 in poi) che implementano tecniche di ottimizzazione delle prestazioni quali:

- **Esecuzione Fuori Ordine (*Out-of-Order Execution* — OoOE):** capacità del processore di riordinare la sequenza di istruzioni macchina eseguendo immediatamente quelle i cui operandi sono già pronti, senza attendere il completamento di istruzioni precedenti temporaneamente bloccate da accessi lenti alla memoria RAM;
- **Esecuzione Speculativa (*Speculative Execution*) e Branch Prediction:** meccanismo per cui il processore predice l'esito di un salto condizionato o di un controllo ed esegue in anticipo il blocco di istruzioni associato. Se la predizione si rivela corretta, le prestazioni aumentano notevolmente; se la predizione si rivela errata, il processore esegue un rollback dello stato architetturale dei registri (*retirement pipeline*), scartando i risultati come se le istruzioni non fossero mai state eseguite.

Il meccanismo dell'attacco speculativo

Il difetto strutturale alla base di Meltdown risiede nel fatto che, durante l'esecuzione speculativa fuori ordine, le CPU vulnerabili omettevano di verificare in tempo reale i permessi di privilegio sui registri di protezione della memoria prima di eseguire la lettura di un indirizzo di memoria kernel da parte di un processo in spazio utente (*Ring 3*). L'eccezione hardware di violazione di memoria (*Page Fault*) veniva sollevata soltanto al momento del completamento formale dell'istruzione (*retirement*).

Sebbene il processore azzeri lo stato architetturale dei registri a seguito della violazione, l'esecuzione speculativa ha comunque alterato lo **stato micro-architetturale del processore**, nello specifico le linee della **data cache**. Un attaccante privo di privilegi può quindi orchestrare un attacco di canale laterale (*cache side-channel attack*) basato sulla celebre tecnica **FLUSH+RELOAD**:

1. **Fase 1 (Flush):** Il processo malevolo alloca in memoria utente un array sonda composto da 256 pagine di memoria da 4096 byte ciascuna:

   $$\text{Array}[256 \times 4096]$$

   Tramite l'istruzione assembly dedicata `clflush`, l'attaccante svuota integralmente tutte le linee della cache CPU associate a ciascuna delle 256 pagine dell'array, garantendo che nessuna di esse sia presente nella cache L1/L2/L3.
2. **Fase 2 (Speculative Access):** L'attaccante innesca l'esecuzione di una sequenza di istruzioni transienti che tentano di leggere un byte segreto protetto $K \in [0, 255]$ situato a un indirizzo arbitrario della memoria kernel:

   ```
   // Istruzione illegale da Ring 3: genera eccezione di Page Fault
   char secret_byte = *(kernel_virtual_address);
   // Istruzione transiente eseguita speculativamente prima del trap
   val = Array[secret_byte * 4096];
   ```

   La CPU esegue speculativamente la seconda riga prima che la violazione di accesso della prima riga venga finalizzata: l'accesso all'indirizzo `&Array[`$K \times 4096$`]` carica la linea di cache corrispondente alla pagina K. Quando il processore rileva l'accesso illegale, scarta i registri e lancia il Page Fault, ma la linea di cache rimane caricata.

3. **Fase 3 (Reload & Measure):** L'attaccante cattura l'eccezione (tramite signal handler o istruzioni transazionali) ed esegue un ciclo di lettura su tutte le 256 pagine dell'array, misurando i cicli di clock necessari all'accesso mediante l'istruzione ad altissima risoluzione `rdtsc` (*Read Time-Stamp Counter*):
   - Le 255 pagine non caricate provocano un *cache miss* e richiedono centinaia di cicli di clock per essere recuperate dalla memoria RAM principale;
   - L'unica pagina corrispondente all'indice K provoca un *cache hit* immediato, rispondendo in una manciata di cicli di clock (< 50 cicli).

   Dalla misura del tempo di accesso, l'attaccante deduce con certezza assoluta il valore numerico del byte segreto del kernel, infrangendo completamente la confidenzialità della memoria fisica del sistema (chiavi crittografiche, password di root, dati di altri processi o di altre macchine virtuali in ambienti cloud multi-tenant).

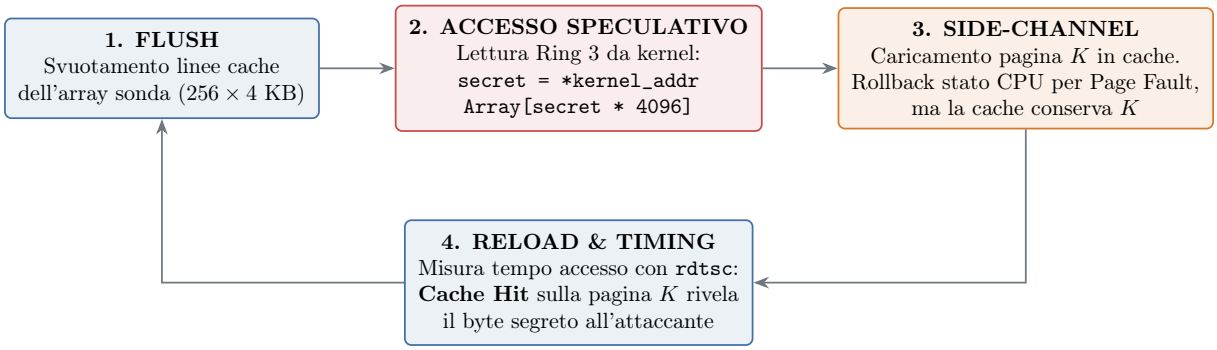


Figura 2.2: Dinamica operativa dell'attacco Meltdown (CVE-2017-5754) basato su esecuzione speculativa fuori ordine e tecnica di canale laterale di cache FLUSH+RELOAD.

Meltdown è correlata alla debolezza fondamentale del codice e dell'hardware catalogata come **CWE-200** (*Information Exposure*).

Mitigazioni e costi prestazionali (KPTI)

Trattandosi di un difetto intrinseco al silicio delle CPU fisiche, Meltdown non ha potuto essere risolta mediante una correzione hardware immediata sui miliardi di processori già immessi sul mercato. La comunità dei sistemi operativi (Linux, Windows, macOS) ha dovuto sviluppare d'urgenza una mitigazione software a livello di kernel denominata **KPTI (Kernel Page Table Isolation)**, originariamente sviluppata con il nome di *KAISER*.

In condizioni ordinarie, per massimizzare le prestazioni delle chiamate di sistema (*syscall*), il kernel condivideva le medesime tabelle di paginazione virtuale con lo spazio utente, limitandosi a marcare le pagine del kernel con un flag di protezione che impediva l'accesso esplicito ma non bloccava la lettura speculativa. KPTI ha scisso radicalmente le tabelle delle pagine: quando un processo è in esecuzione in spazio utente, la tabella delle pagine contiene esclusivamente la memoria utente e un nucleo strettamente minimale di routine del kernel per la gestione degli interrupt. Ad ogni transizione tra spazio utente e spazio kernel, il sistema operativo deve forzare il cambio del registro di controllo `CR3`, innescando lo svuotamento continuo e l'invalidazione della **TLB (Translation Lookaside Buffer)**.

Questo continuo overhead di cambio contesto ha comportato una **drastica riduzione delle prestazioni complessive dei sistemi affetti, con penalizzazioni misurate tra il 5% e punte superiori al 30%** in carichi di lavoro intensivi di I/O, operazioni su database e virtualizzazione, evidenziando il drammatico trade-off tra sicurezza architetturale ed efficienza operativa.

2.3.2 EPSS – Exploit Prediction Scoring System

Per completare le informazioni su quanto possono essere pericolose le vulnerabilità per un'azienda interessata a svolgere un'analisi dei rischi, e per superare i limiti strutturali del punteggio CVSS, è stato introdotto l'**EPSS (Exploit Prediction Scoring System)**.

Il punteggio CVSS descrive infatti il **danno teorico massimo potenziale** nel caso in cui una vulnerabilità venga sfruttata con successo in condizioni ideali; tuttavia, da statistiche storiche di settore, **meno del 5-7% di tutte le vulnerabilità censite con CVE viene effettivamente sfruttato nel mondo reale in attacchi informatici su larga scala**. Applicare le patch basandosi esclusivamente sul valore del CVSS (assegnando ad esempio priorità assoluta a qualunque vulnerabilità con punteggio ≥ 7.0 o ≥ 9.0) genera una situazione di paralisi operativa per i team di sicurezza aziendali (*vulnerability overload* e affaticamento da alert), costretti a testare e distribuire migliaia di patch per vulnerabilità che non verranno mai aggredite.

L'EPSS, sviluppato e mantenuto aggiornato quotidianamente dall'organizzazione non-profit **FIRST** (https://www.first.org/epss/), risolve questo divario. Si tratta di un modello statistico predittivo avanzato (basato su tecniche di machine learning supervisionato) che stima la **probabilità oggettiva compresa tra 0 e 1 (ossia tra lo 0% e il 100%)** che una data vulnerabilità software venga attivamente sfruttata nel mondo reale (*in the wild*) nei **successivi 30 giorni**.

Il modello di stima dell'EPSS aggrega in tempo reale enormi volumi di dati dinamici raccolti da Internet:

- Dati di telemetria e rilevamento attacchi provenienti da reti globali di honeypot e sensori IDS/IPS distribuiti;
- Attività nei canali e mercati del dark web e nei forum underground;
- Pubblicazione e diffusione di codice di exploit su repository pubblici (es. Exploit-DB, GitHub, Metasploit);
- Segnalazioni di intelligence e discussioni attive della comunità di analisti su social network e feed tecnici;
- Metadati intrinseci della vulnerabilità (CVSS, vendor affetto, tipologia di debolezza CWE).

Accanto alla probabilità assoluta, l'EPSS associa a ciascuna CVE un valore di **percentile** ($0 \ldots 100\%$), che indica la frazione di tutte le altre vulnerabilità note che presentano un punteggio EPSS uguale o inferiore. Ad esempio, una CVE con percentile del 98% si colloca nel 2% delle vulnerabilità a maggior rischio di sfruttamento attivo dell'intero panorama globale.

Un ulteriore strumento fondamentale, complementare all'EPSS, è il catalogo **KEV (Known Exploited Vulnerabilities)** gestito dall'agenzia federale statunitense **CISA** (*Cybersecurity and Infrastructure Security Agency*). Il catalogo CISA KEV censisce le vulnerabilità per le quali esiste un'evidenza certa, empirica e documentata di sfruttamento malevolo attivo in incidenti reali. Mentre il KEV fornisce un'evidenza binaria (la vulnerabilità è già attivamente sfruttata nel mondo reale), l'EPSS offre una funzione predittiva continua probabilistica che stima se e con quale probabilità lo sfruttamento accadrà a breve termine.

Esempio empirico: evoluzione dell'EPSS di Meltdown

Considerando la vulnerabilità Meltdown (CVE-2017-5754), è interessante osservare come l'EPSS sia variato nel tempo, evidenziando la natura puramente dinamica del rischio reale rispetto al valore statico del CVSS:

- **Gennaio 2018 (Divulgazione pubblica):** Al momento della disclosure pubblica, il punteggio EPSS associato a Meltdown era relativamente contenuto (circa 0.02, corrispondente a una probabilità di sfruttamento del 2% nei successivi 30 giorni), a fronte di un punteggio base CVSS elevato pari a 5.6 (valutato all'epoca secondo metriche locali). Tale valore iniziale rifletteva il fatto che, sebbene l'impatto teorico sulla confidenzialità fosse devastante, la

realizzazione pratica di un exploit affidabile richiedeva competenze di ingegneria micro-architetturale e di reverse engineering estremamente avanzate, oltre all'accesso locale alla macchina.

- **Settimane successive (Febbraio 2018):** Con la pubblicazione di molteplici proof-of-concept verificati e funzionanti sui repository pubblici e con l'integrazione di script automatici nei framework di attacco, l'EPSS è cresciuto costantemente, superando il picco del $5 - 8\%$.
- **Mesi successivi:** A seguito della distribuzione massiva delle patch software KPTI e dell'aggiornamento dei microcodici da parte dei vendor di hardware e sistemi operativi, il bacino di bersagli vulnerabili si è drasticamente ridotto e l'EPSS è progressivamente sceso stabilizzandosi attorno allo 0.005 (0.5%).

Questo andamento dimostra come l'EPSS catturi dinamicamente l'evoluzione della minaccia, fornendo una guida indispensabile per prioritizzare gli interventi di remediation.

2.4 Window of exposure

Il concetto di **Window of Exposure (finestra di esposizione)** definisce l'intervallo temporale ad alto rischio che intercorre tra la nascita o la scoperta di una vulnerabilità e la sua definitiva correzione e bonifica all'interno dell'infrastruttura operativa.

L'evoluzione temporale di una vulnerabilità e della relativa curva di rischio attraversa una sequenza formale di istanti critici, come schematizzato in Figura 2.3:

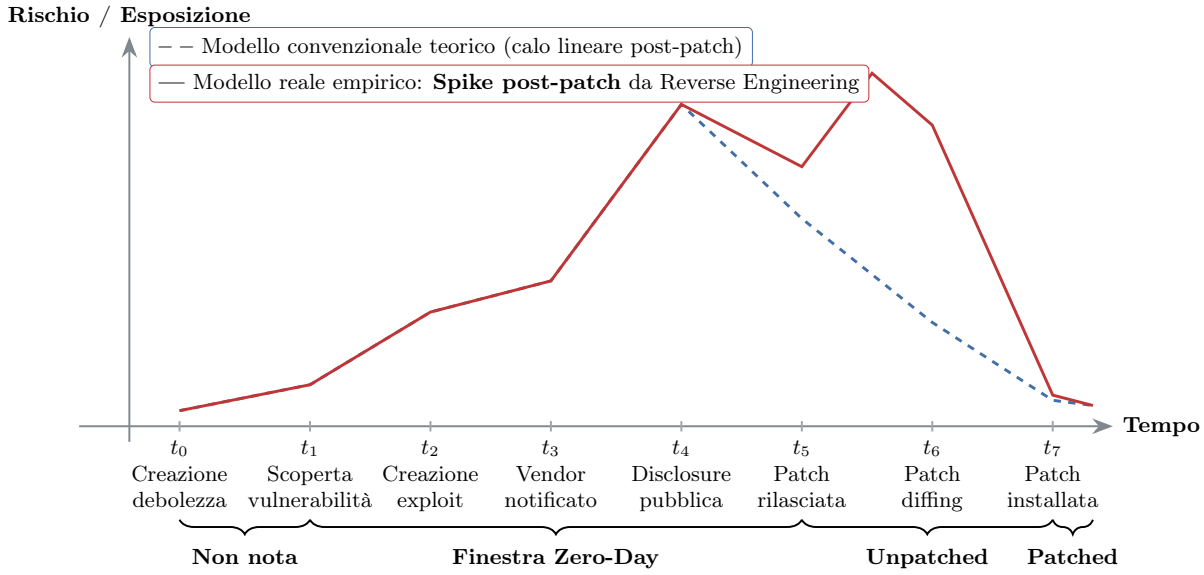


Figura 2.3: La Finestra di Esposizione (*Window of Exposure*): confronto tra il modello teorico convenzionale e l'andamento reale empirico caratterizzato dal picco di rischio successivo al rilascio pubblico della patch correttiva.

Le transizioni fondamentali del ciclo di vita si articolano come segue:

- **Dallo stato non nota a nota (t_1):** la vulnerabilità passa dallo stato di non nota a nota quando viene individuata per la prima volta. Fintanto che la scoperta rimane confinata a un singolo attore, l'esposizione globale è virtualmente nulla, ma l'organizzazione bersagliata potrebbe subire attacchi mirati avanzati (*stealth*).
- **Sviluppo dell'exploit (t_2):** la vulnerabilità diventa concretamente **pericolosa** nel momento in cui viene realizzato un *exploit*, ossia un artefatto software che dimostra la fattibilità tecnica

dello sfruttamento della debolezza violando i controlli di sicurezza. L'esistenza dell'exploit prova inequivocabilmente che la debolezza teorica è una vulnerabilità reale.

- **Notifica al vendor (t_3):** il ricercatore etico notifica privatamente il produttore per consentirgli di avviare l'analisi del bug e la compilazione della patch (*finestra di grazia* o coordinamento confidenziale).
- **Divulgazione pubblica (*Disclosure*, t_4):** il rischio complessivo subisce un'impennata verticale quando i dettagli della vulnerabilità vengono resi pubblici. L'esposizione aumenta esponenzialmente poiché la platea di attaccanti a livello globale in grado di acquisire informazioni e tentare lo sfruttamento si allarga a dismisura. In questa fase intermedia, prima del rilascio della patch, i team di difesa devono aggiornare immediatamente gli strumenti di monitoraggio perimetrale (firewall, IDS/IPS, regole SIEM) con firme provvisorie per rilevare e bloccare i tentativi di penetrazione.
- **Rilascio della patch (t_5):** il produttore rilascia la correzione ufficiale: la vulnerabilità cessa di essere considerata uno *zero-day* e si trasforma in *unpatched*.
- **Il paradosso del rilascio della patch e il Patch Diffing (t_6):** Secondo il diagramma teorico tradizionale, dopo il rilascio della patch il livello globale di rischio dovrebbe calare monotonicamente fino a spegnersi con l'installazione su tutti i dispositivi affetti. Tuttavia, la comunità scientifica e gli analisti di sicurezza evidenziano una realtà empirica radicalmente diversa: **il rilascio pubblico di una patch genera un picco temporaneo ad altissimo rischio**.

  Nel momento esatto in cui un fornitore rilascia un aggiornamento binario, i gruppi criminali scaricano la patch ed eseguono una procedura automatizzata di **Binary Diffing / Patch Diffing** (confrontando byte per byte il codice binario dell'eseguibile precedente con quello aggiornato). Tramite questo reverse engineering mirato, gli attaccanti individuano in poche ore la funzione modificata, deducono l'errore originario, identificano la vulnerabilità e creano rapidamente un exploit funzionante (denominato **1-Day Exploit**). Poiché una vasta porzione di aziende e utenti finali impiega settimane o mesi per testare e installare la patch, la finestra immediatamente successiva al rilascio è caratterizzata da una proliferazione massiva di attacchi automatizzati contro i sistemi non ancora aggiornati.
- **Installazione della patch (t_7):** l'amministratore installa e verifica la patch su tutti i nodi: il sistema transita nello stato definitivo di *patched*, chiudendo la finestra di esposizione.

2.4.1 Mercati zero-day e politiche di divulgazione (ZDI)

Le vulnerabilità **zero-day** rappresentano la merce più preziosa dell'ecosistema della cybersecurity. L'acquisizione di tali vulnerabilità avviene su tre mercati distinti:

- **White Market:** canali ufficiali e programmi di *Bug Bounty* gestiti direttamente dai vendor (es. Google, Apple, Microsoft) o da piattaforme di crowdsourcing autorizzate (es. HackerOne, Bugcrowd), in cui i ricercatori ricevono compensi per notificare privatamente i difetti consentendo lo sviluppo della patch;
- **Grey Market:** broker e società private (es. Zerodium, Crowdfense) che acquistano exploit zero-day esclusivi per rivenderli a prezzi milionari ad agenzie governative di intelligence e forze di polizia per operazioni di sorveglianza mirata;
- **Black Market:** forum underground nel dark web dove exploit e vettori d'attacco sono scambiati illegalmente tra organizzazioni criminali per condurre campagne di ransomware e frodi informatiche.

In questo scenario, l'organizzazione **Zero Day Initiative (ZDI)**, fondata originariamente da TippingPoint e gestita da Trend Micro, opera come intermediario etico tra i ricercatori indipendenti e i fornitori di software. ZDI acquista le vulnerabilità dai ricercatori e notifica privatamente il vendor interessato, imponendo una rigorosa **deadline vincolante di 120 giorni** per lo sviluppo e il rilascio della patch correttiva. Qualora il fornitore non rispetti tale scadenza

o trascuri la gravità del problema, ZDI procede con la divulgazione pubblica non coordinata della vulnerabilità (*Full Disclosure* senza patch). Questa politica serve a evitare che i produttori posticipino indefinitamente la risoluzione delle falle di sicurezza, proteggendo gli utenti finali tramite un meccanismo di responsabilizzazione forzata.

2.5 Risk Management Framework (RMF)

Il modello di riferimento architetturale consigliato dagli standard internazionali e formalizzato dal **NIST (National Institute of Standards and Technology)** per governare la sicurezza informatica in modo strutturato e scientifico è il **Risk Management Framework (RMF)**.

I documenti normativi cardine pubblicati dal NIST su questa disciplina comprendono:

- **NIST SP 800-39:** *Managing Information Security Risk: Organization, Mission, and Information System View* (definisce la visione globale su tre livelli: organizzazione, missione/processi di business, e sistemi informativi);
- **NIST SP 800-30 Rev. 1:** *Guide for Conducting Risk Assessments* (linee guida dettagliate per l'esecuzione rigorosa dell'assessment);
- **NIST SP 800-37 Rev. 2:** *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy* (processo applicativo strutturato);
- **NIST SP 800-53 Rev. 5:** *Security and Privacy Controls for Information Systems and Organizations* (il catalogo universale dei controlli di sicurezza);
- **NIST SP 800-53A Rev. 5:** *Assessing Security and Privacy Controls in Information Systems and Organizations.*

Secondo la pubblicazione NIST SP 800-39, il processo globale di gestione del rischio si articola in **quattro macro-fasi cicliche e ricorsive**:

1. **Risk Framing (Inquadramento e Preparazione):** Questa fase iniziale stabilisce il contesto strategico e i presupposti operativi per l'intero processo di gestione del rischio. In essa l'organizzazione:
   - Stabilisce l'ambito e i confini del sistema da proteggere, delimitando con precisione il perimetro tecnologico, organizzativo e giuridico;
   - Identifica e censisce tutti gli asset materiali e immateriali (inclusa la reputazione aziendale, il valore del marchio e i dati regolati), determinando il loro valore economico per l'organizzazione;
   - Formalizza i vincoli normativi applicabili (es. GDPR, NIS2, DORA, PCI-DSS);
   - Definisce la tolleranza al rischio dell'organizzazione (*Risk Appetite* e soglie di accettabilità);
   - Produce come output principale la descrizione dettagliata della **metodologia di valutazione** che verrà impiegata, comprensiva delle metriche, delle formule matematiche di calcolo del rischio e dei criteri di classificazione. La metodologia deve essere rigorosamente **ripetibile**, garantendo coerenza di giudizio nel tempo e tra analisti differenti, oltre a preservare il know-how aziendale dal turnover del personale tecnico.
2. **Risk Assessment (Valutazione del Rischio):** In questa fase si procede all'identificazione sistematica e oggettiva dei fattori di pericolo. Si analizzano le minacce (sia intenzionali che accidentali/ambientali), le debolezze architetturali e le vulnerabilità tecniche (interne ed esterne al perimetro). Per ciascun binomio minaccia-vulnerabilità si stimano:
   - Gli **impatti potenziali** derivanti dalla compromissione di Confidenzialità, Integrità o Disponibilità, quantificando i danni finanziari diretti (es. perdite economiche immediate, sanzioni amministrative) e indiretti (es. interruzione operativa prolungata, perdita di clienti, danno reputazionale e spese legali);

- La **probabilità di accadimento (*Likelihood*)**, ponderando l'efficacia dei controlli di sicurezza già operativi, le competenze e i mezzi a disposizione degli agenti di minaccia, e l'attrattività dell'asset.

L'output è una mappatura esaustiva e gerarchizzata del profilo di rischio aziendale, coerente con le direttive definite nella fase di framing.

3. **Risk Response / Mitigation (Risposta e Mitigazione):** Sulla base del profilo di rischio quantificato, la dirigenza aziendale individua, valuta e implementa le strategie di trattamento più adeguate. Ciascuna contromisura tecnica o procedurale viene valutata confrontando il costo di implementazione e manutenzione, i tempi di messa in opera e l'impatto effettivo sulla riduzione del rischio. La fase deve considerare quattro alternative strategiche (approfondite in Sezione 2.7): *Mitigazione*, *Trasferimento*, *Evitamento* e *Accettazione*. Ogni decisione finale deve essere formalmente motivata, oggettiva e documentata nel registro dei rischi.
4. **Risk Monitoring (Monitoraggio Continuo):** Questa fase non rappresenta un adempimento conclusivo ma un'attività **permanente e continuativa**. La sicurezza non è uno stato statico raggiunto una volta per tutte, bensì un processo continuo di vigilanza. Il monitoraggio si occupa di:
   - Valutare l'efficacia operativa sul campo delle contromisure implementate, verificando che i controlli operino come previsto;
   - Verificare la persistenza delle assunzioni formulate nelle fasi precedenti, poiché le tecnologie, l'architettura aziendale e le tattiche degli avversari evolvono continuamente;
   - Monitorare la conformità alle policy interne e raccogliere metriche oggettive sull'efficienza di sicurezza;
   - Gestire l'iterazione ciclica del processo: in presenza di scostamenti significativi, nuove minacce emergenti o inefficacia dei controlli, il processo viene retroazionato, riavviando un ciclo completo a partire dal Risk Framing o applicando revisioni mirate alle fasi intermedie.

   In questo contesto, è opportuno chiarire una distinzione lessicale e concettuale spesso fonte di confusione: **il monitoraggio tecnico non coincide con il Risk Monitoring**. Il *monitoraggio tecnico* è un'attività operativa continuativa (sniffing dei pacchetti, analisi dei log tramite IDS/IPS e SIEM) volta a rilevare attacchi e tentativi di penetrazione in tempo reale; il **Risk Monitoring** è il processo di governance di livello superiore che ingloba le evidenze del monitoraggio tecnico per riesaminare criticamente le assunzioni del modello di rischio, verificare se le formule definite in fase di framing siano ancora valide (ad esempio, aggiornando le stime di probabilità se aumentano gli attacchi provenienti da specifiche aree geografiche) e reimpostare le priorità aziendali.

Nella declinazione operativa specifica per i sistemi informativi delineata dal NIST SP 800-37 Rev. 2, questo ciclo viene ulteriormente declinato in sette passi esecutivi:

1. **Prepare:** attività preparatorie a livello sia aziendale che di singolo sistema;
2. **Categorize:** categorizzazione del sistema e delle informazioni elaborate in base all'impatto sulla sicurezza (secondo FIPS 199);
3. **Select:** selezione della baseline iniziale dei controlli di sicurezza (NIST SP 800-53) e personalizzazione (*tailoring*);
4. **Implement:** implementazione dei controlli selezionati all'interno dell'architettura;
5. **Assess:** collaudo e accertamento che i controlli siano implementati correttamente e raggiungano i risultati desiderati;
6. **Authorize:** autorizzazione formale all'operatività del sistema rilasciata dall'autorità designata (*Authorizing Official*). Questo passo ha una valenza giuridica e manageriale decisiva: il vertice aziendale convalida la postura di sicurezza e **accetta formalmente il rischio residuo** per tutte quelle situazioni in cui si è deciso di non implementare mitigazioni ulteriori perché il rischio è stato valutato come tollerabile o non economicamente conveniente da ridurre;

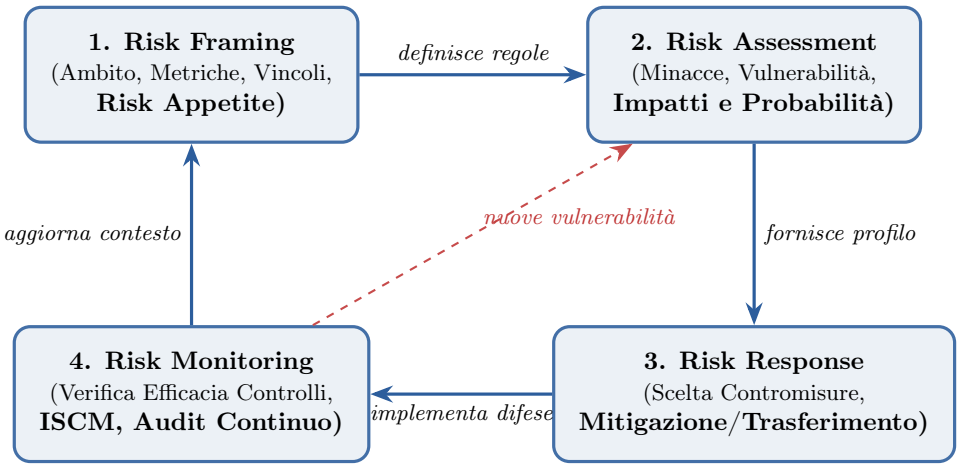


Figura 2.4: Il ciclo di vita ricorsivo del Risk Management Framework (NIST SP 800-39). La fase di Monitoring garantisce la reattività continua rialimentando le fasi di Framing e Assessment.

7. **Monitor:** monitoraggio continuo della postura di sicurezza e dell'efficacia dei controlli.

2.6 Vulnerability assessment

Il **Vulnerability Assessment (VA)** è un processo tecnico strutturato volto a identificare, quantificare e classificare l'esposizione di un'infrastruttura informatica alle vulnerabilità note di sicurezza, focalizzandosi prevalentemente sui servizi di rete e sui sistemi host.

È fondamentale evidenziare che il Vulnerability Assessment **non costituisce una fase autonoma o alternativa** dell'RMF; esso rappresenta bensì un'attività tecnica specifica, strumentale e subordinata, che si colloca come una sottofase operativa del **Risk Assessment**. Mentre il Risk Assessment valuta l'impatto strategico, i rischi legali, gli aspetti economici e la probabilità complessiva legata alle motivazioni degli aggressori, il Vulnerability Assessment produce l'inventario tecnico grezzo delle vulnerabilità (CVE) presenti sui singoli componenti digitali.

Il processo di Vulnerability Assessment si articola in quattro fasi sequenziali:

1. **Planning (Pianificazione):** Definizione rigorosa dei parametri operativi dell'attività:
   - *Scope (Perimetro):* identificazione esatta dei target autorizzati (intervalli di indirizzi IP, sottoreti, singoli host, domini o applicazioni web), escludendo esplicitamente sistemi terzi o nodi mission-critical incompatibili con lo scanning;
   - *Schedule (Tempistica):* definizione delle finestre temporali di esecuzione (tipicamente durante orari notturni o festivi a basso traffico per prevenire disservizi o saturazione di banda);
   - *Regole di ingaggio (Rules of Engagement):* autorizzazione formale e scritta rilasciata dai vertici aziendali che legittima l'attività di scansione, specificando se condurre scansioni dall'esterno del perimetro o dall'interno della rete locale.
2. **Information Gathering (Raccolta Informazioni e Host Discovery):** Acquisizione della topologia di rete e individuazione degli host attivi. Per ciascun target, l'obiettivo primario è determinare il sistema operativo installato e la versione esatta dei servizi in ascolto, elemento indispensabile per correlare le vulnerabilità note. Le tecniche di *Host Discovery* comprendono:
   - **ARP Request Scanning:** utilizzato esclusivamente nelle reti locali (Layer 2) per mappare gli indirizzi MAC associati a ciascun IP attivo in modo istantaneo e non bloccabile;

- **ICMP Echo Request (Ping):** invio di pacchetti ICMP Tipo 8. Spesso inefficace o parziale poiché i moderni firewall e i sistemi operativi (es. Windows Firewall) bloccano di default le risposte ICMP;
- **TCP SYN Ping:** trasmissione di pacchetti TCP con flag SYN impostato verso porte standard note (es. 80, 443, 445); la ricezione di un SYN/ACK (porta aperta) o di un RST (porta chiusa) attesta che l'host è attivo indipendentemente dai filtri ICMP;
- **UDP Probe:** invio di pacchetti UDP su porte specifiche (es. 53 DNS, 161 SNMP); l'assenza di risposte o la ricezione di un ICMP Port Unreachable conferma la raggiungibilità del nodo.

3. **Scanning (Scansione Attiva delle Vulnerabilità):** Esecuzione dei test tecnici sulle macchine rilevate. Si suddivide in sotto-tecniche specializzate:
   - **Port Scanning:** scansione delle porte TCP e UDP per determinare lo stato di ciascun endpoint. Secondo la classificazione convenzionale:
     - *Open (Aperta):* un servizio o un'applicazione è attivamente in ascolto sulla porta e risponde accettando connessioni (ad es. risponde con SYN/ACK a un probe SYN);
     - *Closed (Chiusa):* la porta è raggiungibile ma nessun servizio è in ascolto; l'host risponde inviando immediatamente un pacchetto TCP con flag RST (*Reset*);
     - *Filtered (Filtrata):* lo scanner non è in grado di determinare se la porta sia aperta o chiusa poiché le sonde vengono bloccate e scartate (*dropped*) silenziosamente da un firewall o da un dispositivo di filtraggio intermedio, senza generare alcuna risposta o restituendo errori ICMP di tipo *Destination Unreachable (Communication Administratively Prohibited)*.
   - **OS Detection (Fingerprinting del Sistema Operativo):** Gli scanner identificano il sistema operativo e spesso il numero esatto di build/kernel analizzando la risposta dello stack TCP/IP alle sonde. Poiché ogni sistema operativo (Linux, Windows, macOS, FreeBSD, Cisco IOS) implementa la suite di protocolli con minime discrepanze euristiche, lo scanner esamina parametri quali il valore iniziale del TTL (*Time-To-Live*), la dimensione della finestra di ricezione (*TCP Window Size*), la presenza del flag *DF (Don't Fragment)*, l'ordine delle opzioni TCP e il comportamento anomalo di risposta a pacchetti malformati o flag incoerenti (es. scansioni FIN, Xmas o Null).
   - **TCP Sequence Predictability Classification:** Lo scanner tenta di analizzare la sequenza di numeri casuali generati dal sistema operativo bersaglio per popolare il campo *Initial Sequence Number (ISN)* nelle connessioni TCP. Se il generatore di numeri pseudocasuali (PRNG) del kernel è difettoso o presenta una predicibilità statistica, un attaccante remoto potrebbe ricostruire la sequenza ed eseguire con successo attacchi di **IP Spoofing** e **TCP Connection Hijacking** alla cieca (inviando pacchetti manipolati senza vedere le risposte legittime).
   - **Vulnerability Matching:** Interrogazione dei servizi tramite *banner grabbing* e invio di payload dedicati non distruttivi per verificare l'effettiva presenza di CVE note sul software identificato.
4. **Report (Stesura del Documento Conclusivo):** Elaborazione di un report esaustivo che non si limita a elencare le vulnerabilità riscontrate, ma le prioritizza in funzione della severità (CVSS) e dell'impatto sul business, formulando proposte strutturate di mitigazione e contromisure secondo tre gradazioni operative:
   - *La soluzione migliore:* la correzione architetturale ideale e completa (es. riscrittura del modulo o upgrade del sistema operativo);
   - *La soluzione più conveniente:* contromisura a basso costo ed esecuzione immediata (es. applicazione di una regola di blocco sul firewall perimetrale o modifica di un parametro di configurazione);
   - *La soluzione suggerita (raccomandata):* il miglior compromesso pratico tra efficacia

protettiva, costi operativi e tempi di fermo macchina.

2.6.1 Strumenti di vulnerability assessment

L'esecuzione manuale del Vulnerability Assessment su infrastrutture composte da centinaia o migliaia di host risulterebbe impraticabile. Esistono pertanto software dedicati in grado di automatizzare integralmente le fasi di discovery, port scanning, associazione delle vulnerabilità e stesura dei report. I principali strumenti adottati nel settore comprendono:

- **Nmap (Network Mapper):** Strumento da riga di comando (CLI) universale, open-source e potentissimo, impiegato sia da amministratori di sistema per fini difensivi sia da aggressori informatici per condurre attività di ricognizione preliminare. Nmap supporta decine di modalità di scansione (SYN Stealth Scan, Connect Scan, UDP Scan, idle zombie scan) ed è equipaggiato con il motore **NSE (Nmap Scripting Engine)**, che consente di eseguire script scritti in Lua per automatizzare verifiche di vulnerabilità specifiche e fingerprinting avanzato. Sebbene la documentazione sia vastissima e lo strumento rimanga imbattibile per analisi mirate e personalizzate, Nmap non è progettato come piattaforma integrata enterprise: genera report grezzi o disorganizzati e richiede la stesura di script personalizzati per orchestrare scansioni complesse e distribuite su molteplici segmenti di rete.
- **GVM (Greenbone Vulnerability Management / OpenVAS):** Soluzione open-source leader per l'automazione dello scanning in ambienti aziendali complessi. GVM combina le attività di host discovery, vulnerability scanning e reporting avanzato in un'unica piattaforma integrata e centralizzata. La versione community (*Greenbone Community Feed*) è liberamente accessibile, ma per accedere ai bollettini delle vulnerabilità più recenti rilasciate nelle ultime 24-48 ore o per testare specifici applicativi commerciali per sistemi non-Linux è richiesta la sottoscrizione del feed commerciale a pagamento (*Greenbone Enterprise Feed*). L'azienda produttrice commercializza inoltre *appliance* hardware e macchine virtuali preconfigurate per semplificare l'integrazione nelle architetture enterprise.
- **Nessus (Tenable):** Storicamente lo scanner di vulnerabilità più diffuso al mondo, originariamente sviluppato come progetto open-source e gratuito. In seguito, la società proprietaria (Tenable) ne ha chiuso il codice sorgente, trasformandolo in un software commerciale a pagamento (pur consentendo un'installazione gratuita limitata a 16 indirizzi IP per scopi didattici o domestici). Fu proprio la chiusura del codice di Nessus a determinare la nascita di OpenVAS come fork comunitario della base di codice libera. A differenza delle primissime versioni storiche, che includevano funzionalità per lanciare direttamente exploit con un semplice click, le versioni moderne di Nessus e dei suoi fork hanno disabilitato qualsiasi funzione di attacco automatico per impedire l'utilizzo improprio o incidenti catastrofici innescati da *script kiddies*[1]. Nessus offre una gestione centralizzata e reportistica di conformità (*compliance*) di altissimo livello.
- **Acunetix:** Soluzione commerciale proprietaria altamente specializzata nell'analisi di vulnerabilità delle applicazioni web (*DAST — Dynamic Application Security Testing*). Dotata di interfacce grafiche estremamente rifinite, crawler avanzati per ambienti JavaScript single-page application (SPA) e motori di correlazione per la rilevazione di vulnerabilità OWASP (SQLi, XSS, CSRF, SSRF), a fronte di costi di licenza significativi.

Architettura dettagliata di GVM / OpenVAS

Per comprendere il funzionamento di uno scanner di vulnerabilità aziendale, in Figura 2.5 viene dettagliata l'architettura modulare di **Greenbone Vulnerability Management (GVM /**

[1] Con il termine dispregiativo *script kiddy* si indicano individui con competenze tecniche superficiali o nulle che utilizzano strumenti e payload automatizzati sviluppati da altri per sferrare attacchi, ignorando completamente i meccanismi interni dell'exploit e le conseguenze collaterali sui sistemi bersaglio.

OpenVAS).

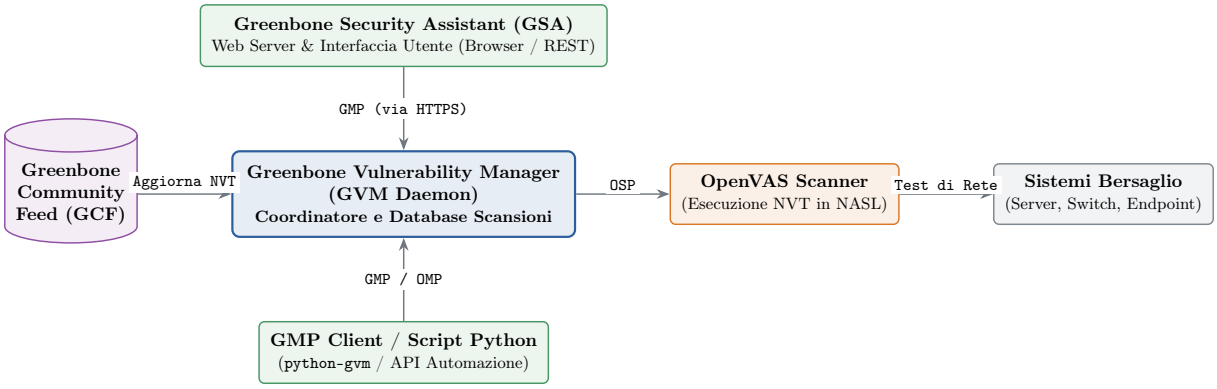


Figura 2.5: Architettura modulare di Greenbone Vulnerability Management (GVM / OpenVAS). I componenti cooperano tramite protocolli standardizzati (GMP, OSP) separando l'interfaccia utente, la logica di orchestrazione e il motore di scansione sul campo.

L'architettura di GVM si basa sulla cooperazione tra entità disaccoppiate:

1. **OpenVAS Scanner:** È il componente responsabile dell'esecuzione materiale dei test di vulnerabilità sul campo. Esso invia sonde di rete e analizza le risposte degli host. Affinché i risultati non vengano alterati o bloccati dai filtri intermedi dei firewall, gli scanner devono essere opportunamente posizionati all'interno della stessa sottorete degli asset o attestati su porte span/mirror di rete. I singoli test eseguiti dallo scanner sono denominati **NVT (Network Vulnerability Tests)**, scritti nel linguaggio dedicato **NASL (Nessus Attack Scripting Language)**.
2. **Greenbone Community Feed (GCF):** È il repository costantemente aggiornato da cui lo scanner attinge l'elenco dei test NVT e le definizioni delle vulnerabilità più recenti.
3. **Open Scanner Protocol (OSP):** Protocollo aperto e standardizzato basato su XML/REST che consente al manager di comunicare e orchestrare non solo gli scanner OpenVAS nativi, ma qualsiasi scanner di terze parti compatibile con la specifica.
4. **Greenbone Vulnerability Manager (GVM):** È il demone centrale e motore logico dell'intera infrastruttura. Gestisce l'inventario degli asset, pianifica e distribuisce i task di scansione verso gli scanner OSP, raccoglie i risultati grezzi, li correla con il database delle vulnerabilità e calcola i punteggi di severità complessivi memorizzandoli nel database relazionale (PostgreSQL).
5. **Greenbone Security Assistant (GSA):** È il server web che espone un'interfaccia grafica interattiva accessibile tramite browser, oltre a rendere disponibili le API REST per gli utenti. Da qui è possibile creare task di scansione, configurare le credenziali per scansioni autenticate e generare report in formato PDF, CSV o XML.
6. **Greenbone Management Protocol (GMP):** Protocollo di gestione (evoluzione del precedente OMP) che regola la comunicazione cifrata e sicura tra l'interfaccia GSA, i client remoti e il manager centrale.
7. **Client Programmatici (Python GVM):** Oltre all'interfaccia web, tutte le funzionalità di GVM sono accessibili programmaticamente tramite librerie software dedicate (es. `python-gvm`). Questo consente di integrare lo scanning di vulnerabilità direttamente nelle pipeline di Continuous Integration e Continuous Deployment (*CI/CD*), avviando scansioni automatiche e bloccando il deployment di immagini o container se emergono vulnerabilità ad alto rischio.

2.7 Valutazione del rischio

La quantificazione del rischio informatico è indispensabile per stabilire un ordine razionale di priorità negli interventi di protezione. L'obiettivo ultimo rimane la riduzione dei rischi entro una soglia di tolleranza concordata mediante l'applicazione mirata di mitigazioni.

La letteratura di sicurezza (in particolare NIST SP 800-30 e ISO/IEC 27005) identifica tre aspetti fondamentali per valutare il rischio associato a un evento avverso:

- **Il danno massimo (e medio) derivante dalla manifestazione del rischio:** parametro cardine che stima le conseguenze peggiori e più probabili in caso di compromissione, quantificando le perdite sia finanziarie che operative a carico degli asset coinvolti;
- **I tempi di recupero (*Recovery Time*) della piena funzionalità:** metrica essenziale per stimare i costi indiretti causati dal blocco della produzione, dai mancati guadagni (*business disruption*) e dall'inoperosità dei dipendenti;
- **La probabilità di accadimento (*Likelihood*):** la stima della frequenza o della verosimiglianza che l'evento negativo si verifichi, consentendo di distinguere rischi concreti e ricorrenti da fenomeni teorici con probabilità trascurabile che possono essere razionalmente accettati.

2.7.1 Tipologie metodologiche di valutazione

A seconda dei dati disponibili, degli obiettivi di governance e del livello di dettaglio richiesto, la valutazione può essere condotta secondo tre approcci metodologici:

1. **Valutazione Quantitativa (Approccio Quantitativo):** Ad ogni rischio viene associato un numero, ad esempio come risultato del calcolo di una formula deterministica. In passato si è fatto largo uso dell'approccio della **monetization** (o monetizzazione), che proponeva di associare un costo ai rischi invece di un punteggio numerico astratto. Di solito, questo punteggio monetario indicava il valore medio (e spesso anche quello massimo) associato al rischio, considerando sia il danno che la probabilità di accadimento. Tale approccio è stato proposto per rendere la valutazione immediatamente comprensibile a chi, a livello di business e consiglio di amministrazione, doveva decidere se finanziare spese e investimenti per la mitigazione dei rischi informatici.
   Il modello classico della monetizzazione si basa sulle seguenti equazioni formali:

$$\mathbf{SLE} = \mathbf{AV} \times \mathbf{EF} \tag{2.1}$$

   dove:
   - **AV** (*Asset Value*): valore economico complessivo dell'asset espresso in valuta (€);
   - **EF** (*Exposure Factor*): fattore percentuale ($0 \leq EF \leq 1$) che quantifica la quota di valore dell'asset distrutta o persa a seguito del singolo evento dannoso;
   - **SLE** (*Single Loss Expectancy*): la perdita economica attesa derivante da un singolo incidente.

   A partire dallo SLE si calcola l'aspettativa di perdita su base annuale:

$$\mathbf{ALE} = \mathbf{SLE} \times \mathbf{ARO} \tag{2.2}$$

   dove:
   - **ARO** (*Annualized Rate of Occurrence*): frequenza stimata di accadimento dell'evento negativo nell'arco di un anno solare (es. un evento che si manifesta in media ogni 4 anni ha un $ARO = 0.25$; un evento atteso due volte l'anno ha un $ARO = 2.0$);
   - **ALE** (*Annualized Loss Expectancy*): la perdita annua complessiva attesa espressa in €/anno.

   L'ALE consente di effettuare valutazioni economiche rigorose sul **Return on Security Investment (ROSI)**: l'adozione di un controllo di sicurezza risulta economicamente giustificata

se e solo se il costo annuo di implementazione e mantenimento della contromisura (C_{control}) è inferiore alla riduzione netta dell'ALE conseguita:

$$\Delta\mathbf{ALE} = \mathbf{ALE}_{\text{pre}} - \mathbf{ALE}_{\text{post}} - C_{\text{control}} > 0 \tag{2.3}$$

Anche se i numeri ottenuti vengono rappresentati con molta precisione, va ricordato che tali valori devono essere valutati unicamente in termini di **ordini di grandezza** (un punteggio o un costo di 5.55 non indica un rischio davvero maggiore di un altro valutato 5.33, mentre è sicuramente più basso di un rischio valutato 112.34). I numeri ottenuti dall'approccio quantitativo sono spesso ingannevoli e creano una falsa illusione di esattezza matematica, data l'enorme varianza insita nella stima dell'ARO e degli impatti intangibili.

2. **Valutazione Qualitativa (Approccio Qualitativo):** I rischi vengono associati a un numero limitato di categorie descrittive ordinate (es. tre valori ordinati del tipo *low*, *moderate*, *high*) sulla base dell'esperienza euristica degli analisti, senza calcoli numerici espliciti. È un metodo rapido e di facile comunicazione verso il management, ma risente di una marcata soggettività.
3. **Valutazione Semi-Quantitativa (Approccio Semi-Quantitativo):** Rappresenta il modello preferito nella pratica aziendale contemporanea: i rischi vengono associati a valori numerici discreti indicativi di categorie qualitative (ad esempio la scala ordinata 1 = low, 2 = moderate, 3 = high, o matrici 5×5). Questo approccio unisce l'intuitività delle categorie qualitative con il vantaggio pratico di poter lavorare con i numeri, rendendo possibile definire delle formule matematiche combinatorie:

$$\textbf{Rischio} = \textbf{Probabilità (Likelihood)} \times \textbf{Impatto (Impact)} \tag{2.4}$$

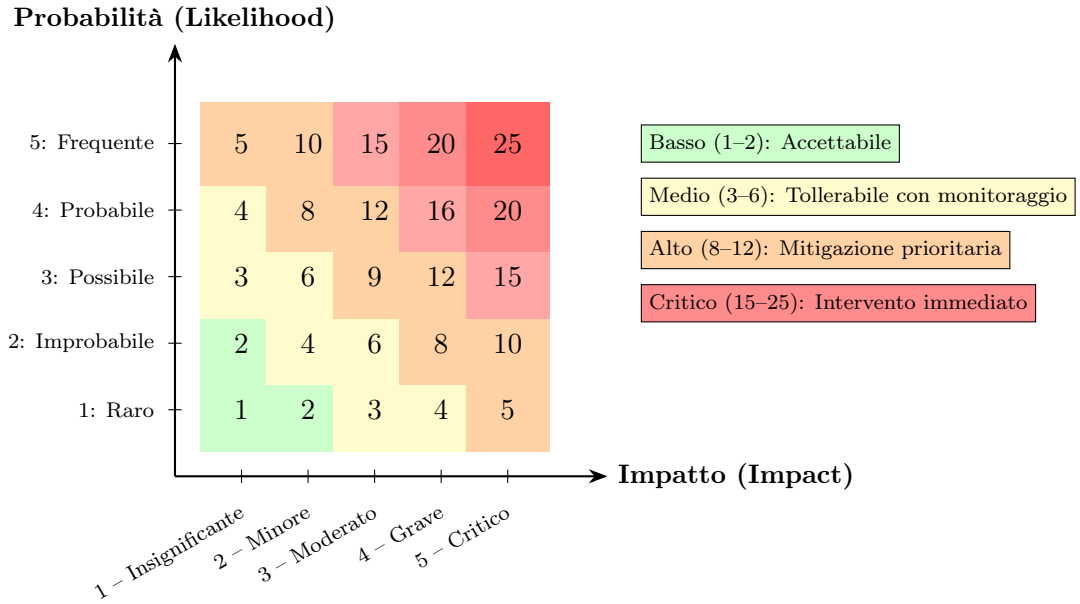


Figura 2.6: Matrice di Rischio Semi-Quantitativa 5×5 (Likelihood vs. Impact). L'obiettivo non è la precisione decimale assoluta (non si misura la velocità della luce), bensì la categorizzazione per fasce di priorità di intervento rispetto alla soglia di tolleranza aziendale.

2.7.2 I tre approcci di analisi del NIST SP 800-30

Il documento NIST SP 800-30 formalizza tre percorsi di analisi, che si differenziano unicamente per il punto di partenza dell'indagine:

1. **Threat-Oriented (Orientato alle Minacce):** Si parte dalla profilazione degli avversari e degli agenti di minaccia (*Threat Agents*), analizzandone competenze tecniche, motivazioni psicologiche ed economiche, budget a disposizione e TTP note. A partire da tale caratterizzazione si deducono le operazioni ostili che gli aggressori sarebbero in grado di lanciare (*Threat Events*) e con quale probabilità. Da qui si esamina quali vulnerabilità e debolezze (*Predisposing Conditions*) presenti nell'infrastruttura verrebbero colpite, calcolando l'impatto tecnico sui sistemi e trasformandolo in danno organizzativo. È l'approccio cardine raccomandato dal NIST per valutare sia i controlli già in essere sia quelli da selezionare.
2. **Asset-Oriented / Impact-Oriented (Orientato agli Asset e all'Impatto):** Si parte dalla mappatura degli asset più critici per l'organizzazione (*mission/business-critical*) e si valutano le conseguenze catastrofiche derivanti dalla perdita della loro confidenzialità, integrità o disponibilità. Successivamente, si identificano a ritroso le minacce che potrebbero avere interesse a colpirli e le vulnerabilità che potrebbero facilitare l'attacco, stimando le probabilità complessive. Questo approccio è concettualmente equivalente a quello threat-oriented, pur procedendo in senso inverso nel grafo delle dipendenze, ed è particolarmente adatto a organizzazioni con asset strategici ben identificabili.
3. **Vulnerability-Oriented (Orientato alle Vulnerabilità):** È un approccio semplificato e parziale che prende avvio direttamente dall'elenco delle vulnerabilità rilevate dagli strumenti di Vulnerability Assessment o dalle CVE note. Utilizzando parametri oggettivi come CVSS ed EPSS, valuta l'*exploitability* per stimare probabilità e conseguenze tecniche. Chi adotta unicamente questo approccio omette spesso di analizzare se esistano attori concretamente interessati a colpire quel target o quali siano le motivazioni reali. Per questa ragione, pur risultando un metodo economico, veloce e diffuso, è considerato accademica mente **più approssimativo, naif e privo di profondità strategica** rispetto ai due precedenti.

2.7.3 Framework di Threat Intelligence e Tassonomie di Sicurezza

Per supportare la modellazione delle minacce e l'identificazione delle difese, la comunità internazionale ha sviluppato solide basi di conoscenza aperte:

- **MITRE ATT&CK (*Adversarial Tactics, Techniques, and Common Knowledge*):** È una knowledge base universale basata su evidenze empiriche del mondo reale che descrive il comportamento degli aggressori attraverso una matrice di **14 tattiche operative** che coprono l'intero ciclo di vita di un attacco avanzato (dall'*Initial Access* all'*Execution*, *Persistence*, *Privilege Escalation*, *Defense Evasion*, *Credential Access*, fino al *Lateral Movement* e all'*Exfiltration*). Ciascuna tattica aggrega centinaia di tecniche e sotto-tecniche documentate con esempi concreti e correlata a **CAPEC** (*Common Attack Pattern Enumeration and Classification*).
- **MITRE D3FEND:** Ontologia e knowledge graph complementare ad ATT&CK che modella formalmente le **contromisure difensive**. D3FEND definisce centinaia di tecniche di mitigazione (articolate in categorie: *Model, Detect, Isolate, Deceive, Evict*) e le collega formalmente agli specifici artefatti digitali e vettori di attacco neutralizzati.
- **ENISA Threat Landscape (ETL):** Report annuale pubblicato dall'agenzia europea per la sicurezza delle reti e dell'informazione, che mappa le minacce emergenti nello spazio cibernetico europeo (Ransomware, attacchi alla supply-chain, disinformazione, violazione dei dati) fornendo dati statistici cruciali per guidare la fase di framing aziendale.
- **OWASP Top 10:** Pubblicata periodicamente dall'Open Web Application Security Project, elenca le 10 classi di vulnerabilità più critiche riscontrate nelle applicazioni web (e recentemente nei Large Language Models). L'edizione **OWASP Top 10 (2025)** censisce:

A1:2025 – *Broken Access Control*
A2:2025 – *Security Misconfiguration*
A3:2025 – *Software Supply Chain Failures*

A4:2025 – *Cryptographic Failures*
A5:2025 – *Injection*
A6:2025 – *Insecure Design*
A7:2025 – *Authentication Failures*
A8:2025 – *Software or Data Integrity Failures*
A9:2025 – *Security Logging and Alerting Failures*
A10:2025 – *Mishandling of Exceptional Conditions*

OWASP formalizza inoltre una **Risk Rating Methodology** semi-qualitativa basata sul prodotto Likelihood × Impact, in cui la Likelihood è scomposta nei fattori dell'Agente di Minaccia (Skill level, Motive, Opportunity, Size) e della Vulnerabilità (Ease of discovery, Ease of exploit, Awareness, Intrusion detection), mentre l'Impact è declinato in fattori Tecnici (perdita di C/I/A e accountability) e fattori di Business (impatto finanziario, danno reputazionale, violazione normativa e privacy).

2.7.4 Le quattro strategie di trattamento del rischio

Una volta completata la valutazione e stimato il profilo di rischio per ciascuno scenario, l'organizzazione deve decidere formalmente quale strategia di trattamento (*Risk Treatment*) adottare, scegliendo tra quattro opzioni codificate da NIST e ISO 27005:

1. **Mitigazione (o Riduzione del Rischio — *Risk Mitigation*):** È la strategia primaria: consiste nell'introdurre controlli di sicurezza tecnici, architetturali o procedurali volti a ridurre la probabilità che la vulnerabilità venga sfruttata (es. installando firewall, applicando patch, abilitando l'autenticazione a più fattori) oppure a limitare le conseguenze dell'impatto (es. predisponendo copie di backup isolate off-line, ridondanza di rete o piani di continuità operativa).
2. **Trasferimento (o Condivisione del Rischio — *Risk Transfer*):** Consiste nel condividere o trasferire l'onere finanziario delle conseguenze dell'attacco verso una terza parte. Si realizza tipicamente attraverso la stipula di una **polizza assicurativa sul rischio cibernetico (*Cyber Insurance*)** oppure mediante la sottoscrizione di contratti di esternalizzazione (*outsourcing*) con fornitori cloud certificati corredati da rigorosi accordi di livello di servizio (SLA) che prevedono penali economiche in caso di disservizio. È fondamentale comprendere che il trasferimento non elimina la vulnerabilità tecnica, ma assicura una copertura finanziaria a fronte del danno subito.
3. **Evitamento (o Annullamento del Rischio — *Risk Avoidance*):** Consiste nell'eliminare alla radice l'attività, la funzionalità o il sistema che genera il rischio inaccettabile. Ad esempio, se un'applicazione web obsoleta presenta vulnerabilità critiche strutturali non correggibili tramite patch e la sua esposizione su Internet comporta un rischio sproporzionato, l'organizzazione sceglie di dismettere completamente l'applicazione o di disattivarne l'accesso pubblico, azzerando l'esposizione.
4. **Accettazione del Rischio (*Risk Acceptance*):** Consiste nella decisione formale e consapevole di non implementare alcuna contromisura aggiuntiva, accettando le conseguenze nel caso in cui l'evento avverso dovesse verificarsi. L'accettazione è una scelta legittima e razionale se e solo se:
   - Il rischio stimato si colloca al di sotto della soglia aziendale di tolleranza (*rischio trascurabile*);
   - Il costo economico e operativo della contromisura supera ampiamente il danno finanziario atteso provocato dall'attacco ($C_{\text{control}} \gg \mathbf{ALE}$).

   L'accettazione deve essere esplicitamente formalizzata, motivata e firmata dai vertici aziendali (*Risk Owner*), escludendo categoricamente l'ignoranza negligente del problema.

2.8 Vulnerability management e patch management

Il **Vulnerability Management** è il processo aziendale permanente e continuo volto a governare il ciclo di vita delle vulnerabilità con l'obiettivo ultimo di **minimizzare la Window of Exposure**.

Il processo muove dalla consapevolezza ingegneristica che il software conterrà inevitabilmente debolezze strutturali e vulnerabilità note; pertanto, la sicurezza di un'organizzazione non si misura dall'illusione dell'assenza di bug, bensì dalla rapidità, efficienza e sistematicità con cui tali difetti vengono rilevati, prioritizzati ed eliminati prima che gli avversari possano sfruttarli.

Nel documento **NIST IR 8011 Vol. 4** (*Automation Support for Security Control Assessments*), il NIST propone di formalizzare questo processo attraverso il continuo confronto tra due stati:

- **Desired State (Stato Desiderato):** Definisce la soglia massima tollerabile di esposizione alle vulnerabilità formalizzata dalle policy aziendali. È caratterizzato da metriche vincolanti, quali il numero massimo ammissibile di vulnerabilità non corrette per ciascuna classe di CVSS (es. zero vulnerabilità critiche con CVSS ≥ 9.0; al massimo 5 vulnerabilità con CVSS ≥ 7.0) e la durata massima consentita del ciclo di remediation (ad es. obbligo inderogabile di installare le patch per vulnerabilità critiche entro 72 ore dalla pubblicazione);
- **Actual State (Stato Reale Effettivo):** Rappresenta la reale postura di sicurezza dell'infrastruttura, costantemente censita tramite strumenti di scansione e monitoraggio continuo (**Information Security Continuous Monitoring — ISCM**).

Lo scostamento tra lo stato effettivo e quello desiderato costituisce il driver operativo che guida gli interventi di bonifica.

All'interno di questo quadro generale, il **Patch Management** costituisce il processo operativo specifico di identificazione, acquisizione, collaudo, installazione e verifica dell'avvenuta applicazione delle patch, degli aggiornamenti e degli upgrade di sicurezza in tutta l'infrastruttura. Il documento di riferimento cardine della disciplina è il **NIST SP 800-40 Rev. 4** (*Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology*).

2.8.1 Ruoli e strategie di patch management

Il NIST SP 800-40 sottolinea che ogni compito di sicurezza essenziale richiede l'attribuzione di responsabilità precise a personale dedicato, formalizzando una netta differenziazione tra chi sviluppa il software e chi lo gestisce in produzione:

- **Software Flaw Manager (SFM):** Ruolo operativo istituito presso le organizzazioni che **sviluppano, commercializzano o mantengono software**. È ricoperto da figure con profonda esperienza nello sviluppo e nella sicurezza del codice. Le sue responsabilità comprendono:
  - Coordinare i processi di scoperta interna delle debolezze mediante audit del codice, analisi statica (SAST), dinamica (DAST) e programmi di *Bug Bounty*;
  - Ricevere, verificare e validare le segnalazioni di vulnerabilità provenienti da ricercatori esterni tramite canali di *Responsible Disclosure*;
  - Supervisionare lo sviluppo tecnico delle patch correttive, assicurando che eliminino la causa radice senza alterare le interfacce legittime né introdurre nuove regressioni;
  - Stabilire la priorità di rilascio dei fix in base alla severità del rischio e all'impatto sugli utenti finali;
  - Comunicare tempestivamente con clienti, enti di standardizzazione (MITRE) e comunità di sicurezza tramite bollettini e advisory ufficiali.
- **Patch Manager (PM):** Ruolo istituito presso le organizzazioni che **utilizzano software e gestiscono infrastrutture IT**. Ha il compito di coordinare tutte le attività connesse all'integrazione e all'applicazione delle patch nell'ambiente operativo. Le sue responsabilità comprendono:

- Monitorare costantemente i feed di sicurezza, i bollettini dei fornitori e le fonti di threat intelligence per intercettare l'emissione di nuove patch;
- Valutare l'applicabilità e la compatibilità effettiva degli aggiornamenti rispetto al parco macchine aziendale e ai relativi sistemi operativi;
- Prioritizzare gli interventi integrando indicatori di gravità intrinseca (CVSS), probabilità di attacco reale (EPSS), presenza nel catalogo CISA KEV e criticità dell'asset per il business;
- Pianificare e coordinare sessioni di collaudo accurato in ambienti di staging e pre-produzione per certificare l'assenza di malfunzionamenti prima del rilascio globale;
- Orchestrare il rollout in produzione minimizzando il fermo dei servizi e mantenendo l'inventario aggiornato dello stato di aggiornamento;
- Gestire formalmente le eccezioni operative, prescrivendo controlli compensativi (es. isolamento di rete o regole WAF) qualora una patch non possa essere immediatamente applicata a sistemi legacy o mission-critical.

Le quattro strategie di deployment del NIST

La necessità di conciliare la tempestività protettiva con la stabilità operativa impone l'adozione di quattro strategie di alto livello raccomandate dal NIST:

1. **Subsets (Distribuzione Incrementale su Sottoinsiemi Pilota):** Consiste nel suddividere il parco macchine aziendale in categorie omogenee e, all'interno di ciascuna categoria, selezionare un piccolo campione pilota rappresentativo a cui distribuire prioritariamente la patch (*canary deployment*). L'obiettivo è verificare la compatibilità sul campo e intercettare tempestivamente comportamenti anomali o instabilità prima di propagare l'aggiornamento all'intera flotta di macchine, confinando il raggio d'azione di eventuali patch difettose.
2. **Standard First (Priorità ai Sistemi Standard):** Raccomanda di applicare le patch primariamente sui sistemi con configurazioni standardizzate, omogenee e ben documentate (es. workstation aziendali standard, server web replicati). Questi nodi costituiscono la maggior parte dell'infrastruttura, sono facilmente riproducibili in ambienti di test e consentono di abbattere l'esposizione al rischio sul maggior numero di dispositivi nel minor tempo possibile con uno sforzo operativo ridotto.
3. **Difficult Ones Later (Gestione Differita dei Sistemi Complessi e Legacy):** I sistemi legacy, gli apparati industriali (SCADA/ICS), i dispositivi medicali connessi o i server che ospitano software datato con delicate dipendenze architetturali non possono essere aggiornati in modo indiscriminato. Questi ambienti vengono affrontati al termine del rollout, pianificando collaudi manuali specialistici, predisponendo piani di rollback dettagliati e attivando misure di sicurezza compensative a livello perimetrale se l'aggiornamento diretto risulta impraticabile.
4. **Cover All (Copertura Esaustiva di Tutti gli Endpoint):** Questa direttiva strategica impone di non tralasciare alcuna categoria di dispositivo connesso. Gli aggressori penetrano frequentemente attraverso nodi considerati marginali o secondari (macchine virtuali dimenticate, ambienti di test/dev, dispositivi mobili BYOD, apparati IoT, interfacce firmware e switch di rete) per muoversi lateralmente verso gli asset più preziosi. Un programma di patching è efficace solo se esteso all'intero inventario senza eccezioni non presidiate.

2.8.2 Affidabilità delle patch e problematiche operative

Sebbene l'applicazione tempestiva delle patch sia un imperativo di sicurezza, il processo di patching è esso stesso portatore di significativi rischi operativi. Una patch introduce modifiche a basso livello nel codice o nel kernel, potendo innescare:

- **Incompatibilità software:** rottura di dipendenze su specifiche versioni di librerie condivise da applicativi aziendali proprietari;

- **Regressioni funzionali:** introduzione involontaria di bug che compromettono servizi precedentemente operativi;
- **Degradazione delle prestazioni:** calo dell'efficienza computazionale (come documentato per le patch KPTI per Meltdown);
- **Instabilità e crash del sistema operativo:** blocco catastrofico (*kernel panic* o BSOD) di server essenziali.

Casi studio emblematici di disastri da patching

L'esempio più devastante della storia informatica recente è l'**incidente CrowdStrike del 19 luglio 2024**. Un aggiornamento automatico difettoso del driver del sensore di sicurezza *Falcon* distribuito a livello kernel su milioni di endpoint Windows in tutto il mondo ha provocato una dereferenziazione di puntatore nullo non gestita, innescando una schermata blu (*Blue Screen of Death* — BSOD) irreversibile e ciclica su oltre 8,5 milioni di sistemi. L'incidente ha paralizzato aeroporti internazionali, banche, servizi ospedalieri di pronto soccorso e catene logistiche globali per giorni, evidenziando la pericolosità estrema dell'assenza di controlli di validazione e di deployment scaglionato a gruppi pilota (*staged rollout*).

Un altro precedente storico significativo è rappresentato da **Apple iOS 8.0.1 (settembre 2014)**: una patch distribuita per correggere bug minori conteneva un errore che ha disattivato la connettività cellulare e il sensore biometrico TouchID su tutti i dispositivi iPhone 6, costringendo il vendor al ritiro d'urgenza dell'aggiornamento a poche ore dal rilascio.

2.8.3 Evoluzione del modello di rilascio: dalle patch singole alle aggregated patch

Storicamente, i fornitori di software rilasciavano patch singole ad-hoc non appena una specifica vulnerabilità veniva corretta. Questo approccio determinava gravi criticità:

- Sovraccarico operativo ingestibile per i sistemisti;
- Continua interruzione di servizio legata ai frequenti riavvii macchina;
- Moltiplicazione esponenziale dei costi e dei tempi di testing in pre-produzione;
- Elevato rischio di conflitti di dipendenza incrociata tra aggiornamenti successivi.

Per razionalizzare il processo, l'industria ha adottato il modello delle **Aggregated Patch (o Patch Bundle)**, che raggruppa decine di correzioni di sicurezza in un unico rilascio cumulativo a cadenza temporale periodica e prevedibile. Il caso di riferimento è il **Microsoft Patch Tuesday**, che fissa la distribuzione degli aggiornamenti cumulativi di sicurezza al secondo martedì di ogni mese.

I benefici di questo modello risiedono nella programmabilità delle finestre di manutenzione, nella riduzione dei riavvii e nella garanzia che il vendor abbia testato congiuntamente l'interazione tra tutte le patch incluse nel bundle. Lo svantaggio risiede tuttavia nell'allungamento forzato della Window of Exposure per le vulnerabilità corrette internamente dal vendor che attendono la data prefissata per essere divulgate; per mitigare questo limite, i produttori mantengono canali straordinari per il rilascio immediato *Out-of-Band (OOB)* di aggiornamenti di emergenza destinati a vulnerabilità critiche attivamente sfruttate nel mondo reale.

2.8.4 Enterprise Patch Management tools (EPM)

Gli **Enterprise Patch Management (EPM) Tools** sono piattaforme software centralizzate che automatizzano e orchestrano il ciclo di vita del patching su larga scala (tra cui Microsoft WSUS/MECM, Red Hat Satellite, VMware vCenter Update Manager, ManageEngine Patch Manager, e soluzioni moderne cloud-native come NinjaOne e Automox). Essi forniscono discovery

automatica, distribuzione remota di pacchetti, pianificazione granulare delle finestre di riavvio, reportistica di conformità e rollback automatizzato.

I rischi sistemici intrinseci degli strumenti EPM

Paradossalmente, l'adozione di una piattaforma EPM centralizzata introduce essa stessa rischi di sicurezza sistemici di massima gravità:

- **Single Point of Failure (SPOF) e canale privilegiato di attacco:** Il server EPM comunica con un agente software installato su ciascun computer dell'infrastruttura ed esegue comandi con i massimi privilegi di sistema (SYSTEM su Windows, root su Linux). Se un gruppo di attaccanti riesce a compromettere il server EPM centrale, ottiene un vettore d'attacco devastante per distribuire simultaneamente ransomware o backdoor crittografate su tutti i nodi aziendali, trasformando uno strumento di difesa nel più efficace moltiplicatore di compromissione;
- **Compromissione delle credenziali privilegiate:** Le chiavi crittografiche o le credenziali di amministrazione dell'EPM consentono il controllo totale della rete;
- **Avvelenamento della catena di fornitura (*Supply Chain Poisoning*):** L'intercettazione dei canali di update o la compromissione del repository delle patch consente la distribuzione di aggiornamenti contraffatti;
- **Il paradosso metaricorsivo (*«Chi controlla il controllore?»*):** Anche il server EPM e i relativi agenti software sono composti da codice e presentano vulnerabilità che devono essere monitorate e corrette tempestivamente.

Linee guida di hardening NIST per gli EPM

Per contrastare queste minacce, il NIST raccomanda l'applicazione obbligatoria delle seguenti misure di hardening sui sistemi EPM:

1. **Isolamento architetturale e micro-segmentazione:** Collocazione del server EPM all'interno di una VLAN di gestione dedicata, protetta da firewall e inaccessibile dalla rete aziendale ordinaria o da Internet;
2. **Autenticazione a più fattori (MFA):** Obbligatoria per qualunque accesso amministrativo alla console di gestione dell'EPM;
3. **Verifica crittografica dell'integrità e dell'autenticità:** Verifica rigorosa delle firme digitali e dei checksum crittografici SHA-256 dei pacchetti di aggiornamento prima della loro immissione nel repository;
4. **Segregazione dei privilegi e Least Privilege:** Limitazione delle autorizzazioni degli agenti al minimo indispensabile per il deployment dei file;
5. **Auditing continuo e logging immutabile:** Tracciamento dettagliato di tutte le attività operative su server di log centralizzati e protetti da manomissione (WORM);
6. **Deployment a blocchi scaglionati (*Staged Deployment*):** Divieto assoluto di rollout simultaneo dell'intera rete, imponendo il passaggio forzato attraverso gruppi pilota e ambienti di test.

L'analisi costi-benefici condotta dal NIST conclude inequivocabilmente che, se protetti attraverso le suddette misure di hardening, gli strumenti EPM rappresentano una necessità non negoziabile per le moderne organizzazioni, poiché i vantaggi derivanti dalla chiusura rapida e automatizzata della Window of Exposure superano ampiamente i rischi residuali.